



File No.: EXP202213023

RESOLUTION OF RECONSIDERATION APPEAL

Examined the reconsideration appeal filed by ORANGE ESPAGNE, S.A.U. (hereinafter, the appellant) against the resolution issued by the Director of the Spanish Agency for Data Protection dated October 22, 2024, and based on the following

FACTS

FIRST: On October 22, 2024, a resolution was issued by the Director of the Spanish Agency for Data Protection in file EXP202213023, by virtue of which ORANGE ESPAGNE, S.A.U. was imposed:

- for a violation of Article 6 of the GDPR, classified under Article 83.5.a) of said regulation, an administrative fine of 200,000 euros (two hundred thousand euros).
- for a violation of Article 25 of the GDPR, classified under Article 83.4 of said regulation, an administrative fine of 1,000,000 euros (one million euros).
- ORDERING ORANGE ESPAGNE, S.A.U., with NIF A82009812, that pursuant to Article 58.2.d) of the GDPR, within a period of 6 months, notify this Agency of the measures it has adopted to ensure that the request for a duplicate is made by the holder of the telephone number, regardless of the procedure used for its issuance.

SECOND: Said resolution, which was notified to the appellant on October 23, 2024, was issued following the processing of the corresponding sanctioning procedure, in accordance with the provisions of Organic Law 3/2018, of December 5, on the Protection of Personal Data and Guarantee of Digital Rights (LOPDGDD), and subsidiarily under Law 39/2015, of October 1, on the Common Administrative Procedure of Public Administrations (hereinafter, LPACAP), regarding the processing of sanctioning procedures.

THIRD: As proven facts of the aforementioned sanctioning procedure, PS/00332/2023, the following was recorded:

PROVEN FACTS

FIRST: It is recorded that, on December 15, 2022, a duplicate of the SIM card owned by the complainant was made without their request, at the establishment owned by "TOWER PHONE, S.L.," located at ***ADDRESS.1 in Madrid, which acts as a franchise of ORANGE, as stated in the franchise contract dated April 1, 2022.

C/ Jorge Juan, 6
www.aepd.es
28001 – Madrid
sedeagpd.gob.es

Thus, in the franchise contract dated April 1, 2022, provided by ORANGE with the entity TOWER PHONE S.L.U., it can be observed:

"Background:

I. That it is part of the activity and corporate purpose of ORANGE to provide and market various telecommunications services, electronic communications, and information society services.

II. That ORANGE ESPAGNE S.L.U., in the development of its corporate purpose, markets its services and has implemented its commercial network in commercial traffic under the brands and other distinctive signs that are its own or whose brand uses it is authorized to assign, being interested in designating franchisees, (...)."

(...).

IV. (...).

V. (...).

Likewise, in the object of the contract, it can be observed:

(...).

(...).

SECOND: ORANGE is responsible for the data processing referred to in this procedure, since according to the definition in Article 4.7 of the GDPR, it is the one who determines the purpose and means of the processing carried out.

In Clause Twenty-Second, relating to the processing of personal data, it is noted:

“Under this contract, the FRANCHISEE, in its capacity as data processor, will carry out the processing of personal data necessary for the correct provision of the services subject to this contract.”

THIRD: It is recorded that, to request the duplicate of the SIM card, ORANGE has implemented an automatic identity document validation system, but that, in some cases (...) of the person requesting the duplicate of said SIM card, (...).

FOURTH: ORANGE has stated that, at the time of contracting the duplicate SIM card of the complainant, “the established protocol was followed by this company by passing an identity document through the verification system (...).”

(...).

C/ Jorge Juan, 6

www.aepd.es

28001 – Madrid

sedeagpd.gob.es

3/63

Regarding the issue of whether the system of (...) verifies the correspondence of the document number and the name of the document holder with the data of the applicant for the procedure, (...).

Therefore, as a general rule, the system (...) does validate the name of the identity document holder with the information of the applicant for the procedure, (...).

FIFTH: (...).

SIXTH: ORANGE has acknowledged that the duplicate of the claimant's SIM card was produced due to an irregularity by agents working in the store where the duplication of the SIM card occurred, (...).

SEVENTH: ORANGE has stated, in its written submission dated March 30, 2023, that it has given its employees the following instructions on how to proceed with the use of the DNI validation system, which are as follows:

- It is mandatory not to make a change or duplicate of a SIM card for a person other than the holder (or administrator or authorized representative of the company as recorded in the systems). The person requesting a duplicate must provide a valid identity document (according to protocol), which will always be validated. (...)
- If the system is not functioning at the time of the request, the agent must open an incident and ask the customer to return the next day.
- The agent managing a duplicate request must request the identity documentation, (...).
- In cases where the identity document (...).

EIGHTH: ORANGE has stated in its written allegations dated December 21, 2023, that it has implemented the following measures in cases of requests for duplicate SIM cards:

- Since August 12, 2022 (...).
- Since August 12, 2022 (...).
- Since April 2021, ORANGE has been limiting the channels from which a duplicate SIM card can be requested (...).

NINTH: ORANGE has stated in its written response to the transfer of the complaint, dated January 30, 2023, as well as in its written response to the request, dated March 30, 2023, and in its allegations regarding the initiation agreement of the present sanctioning file, dated December 21, 2023, that it would have adopted the following measures to prevent fraud arising from the impersonation of agents and/or employees of ORANGE:

- On December 28, 2022, and prior to the notification of this request, a mandatory training module was provided from the School of Sales to the entire distribution channel at points of sale to help and raise awareness among sales teams about the risk of recruiting sales agents to physically duplicate from points of sale.”
- A training module was disseminated to the entire distribution channel with the aim of raising awareness among workers about the existing issues and the obligation to comply with all customer

identification procedures and policies.

- The implementation of a double identification factor has been initiated, with the pilot project already implemented and currently in the testing phase.
- A project has been initiated (...).
- A tool from the Risk Analysis Group has been launched, which allows alerts to be generated in case of possible detection of irregular contracts, and in the case of duplicate SIM cards, it would act as follows:

(...).

(...).

- Since December 14, 2022, as stated by ORANGE in its written allegations regarding the initiation agreement of the present sanctioning file, it would have proceeded with the precautionary suspension of the option that allows point of sale agents to (...), thus being unable to attend to any type of exception.

TENTH: Regarding the case that has motivated this sanctioning file, ORANGE has stated, in its written allegations to the present sanctioning file dated December 21, 2023, that it would have carried out the following actions:

- A complaint has been filed against the responsible agents.
- The implicated agents were dismissed from the establishment.

ELEVENTH: It is noted that, in the complaint filed by the entity TOWER PHONE, S.L., on January 12, 2023, the concept of SIM SWAPPING is defined as follows:

"SIM Swapping is a cyberattack that consists of impersonating a person's identity before their telecommunications service provider and requesting a duplicate of their mobile phone's SIM card in order to access their online banking and operate with it, receiving SMS with the confirmation code for banking transactions on that new SIM, proceeding to divert money from the impersonated person's current account to another owned by the criminals.

The victim, as happens in the present case, only becomes aware of the situation when they lose coverage on their mobile phone, and no matter how much they restart the...

C/ Jorge Juan, 6

www.aepd.es

28001 – Madrid

sedeagpd.gob.es

5/63

device or attempts to seek coverage does not succeed since, upon the activation of the new duplicated SIM that the cybercriminals request from the telephone service company, the SIM inside the victim's phone ceases to function."

TWELFTH: It is recorded that in the complaint filed by TOWER PHONE S.L., it states that "a complaint is filed against A.A.A. with NIE: (...) for possible crime of:

(...)

It is also noted that when discussing the concept of SIM Swapping, it states:

"First of all, it is important to explain what the facts reported here (SIM Swapping) consist of, carried out by the accused B.B.B. on at least December 14, 17, and 21, 2022, at his workplace, the Orange point of sale located at ***ESTABLISHMENT.1 in Madrid (**ADDRESS.1 Madrid)"

(...)

In section four of the complaint, regarding the reported Facts, it states:

"Recently, my client has become aware of the facts that we will detail below, which have been duly verified and contrasted with the respective internal departments of the company, through the issuance of a report and attributed to the accused.

An Internal Investigation Report is attached with its supporting documents prepared and signed by the Store Manager located at ***ADDRESS.1 Madrid, owned by Tower Phone, S.L., (...). The annexes of the internal investigation report are as follows:

Annex 1: supporting documentation of A.A.A.'s work schedule on October 6, 2022 (first impersonation).

Annex 2: supporting documentation of A.A.A.'s work schedule on October 7, 2022 (second

impersonation).

Annex 3: supporting documentation of A.A.A.'s work schedule on October 13, 2022 (third impersonation).

Annex 4: supporting documentation of A.A.A.'s work schedule on November 3, 2022 (fourth impersonation).

Annex 5: supporting documentation of A.A.A.'s work schedule on November 15, 2022 (fifth impersonation).

FIRST, my client became aware of the facts reported here for the first time on October 20, 2022, when he went to the ORANGE store located at ***ADDRESS.1 in Madrid (...) alerting that a few days ago he came to the store and that on the same day he supposedly received a call from ORANGE. The inquiry at the store was regarding an unpaid bill, and the call corresponded to the visit to the store and the unpaid bill to collect it by bank card. After several failed attempts with his card, a guy contacted the client (...) and told him that since they were from the same area, it was a scam, that he should not pay attention, and that they received such customer information through the stores. From the very first moment, the client directly accused A.A.A. (...) to which an email was sent to the supervisor to make them aware of these frauds. (...)

(...)

SECOND, on November 16, 2022, the manager of the ORANGE store (located at ***ADDRESS.1, Madrid) received a call from the ORANGE store in (...), Madrid, indicating that on the previous day, November 15, 2022, at 20:45 hours, a duplicate card had been made for the client C.C.C. using the code of the point of sale corresponding to the ORANGE store located at ***ADDRESS.1 in Madrid. In light of these facts, the manager of the ORANGE store at ***ADDRESS.1 asked the store staff if they had made a SIM card change the previous day since it did not appear as billed in our billing system, and it was verified that the SIM card that had been used was in the store's stock. The staff commented that they had not done it and had no knowledge of it. Having cameras in the store, the video from the day of the events (November 15, 2023) was reviewed, where it was observed that at the time the card duplication was taking place, they were working (...) and A.A.A. was at the cash register computer apparently talking on the phone with a headset.

(...)

Given the seriousness of the facts, all the information was sent that same day to the ORANGE supervisor, and an informative email about what happened was sent.

(...)

Subsequently, on November 18, a response was received from the telephone company ORANGE informing this party that for this procedure, documentation and the signature of another person had been used (...). Likewise, this party was informed that this person went to duplicate the card the day before the fraud with the employee A.A.A. at the ORANGE store located at ***ADDRESS.1, and it is correctly billed.

(...)

It is worth noting that when duplicating a card, the one currently in the system is canceled and replaced with a new one, invalidating the previous card at the same moment; this is normally done when the current card, for example, does not work, the client has lost the mobile phone, or it has been stolen. THE PROTOCOL THAT MUST BE FOLLOWED TO MAKE A DUPLICATE is with the client present in the store and with their original and valid document since we must

C/ Jorge Juan, 6

www.aepd.es

28001 – Madrid

sedeagpd.gob.es

7/63

scan the document for validation and ensure that the account holder is the one making the change of the SIM card.

(...)

THIRDLY, and as a consequence of the previously detailed fraud, this party requests ORANGE to provide all available information in order to proceed with the suspension or termination of the suspect

A.A.A. from the store, and for this, this party needed their Cybersecurity department to ensure how many duplicates from the store at ***ADDRESS.1 have been made that are fraudulent, the timing of such, and the IP that made that duplicate. This IP is especially relevant as it assures us that it was made from the store, and not from another external computer or authorized PC.

This party received confirmation from ORANGE informing of the following duplicates, all of which were made with the IP ***IP.1 corresponding to the computers of the Orange Store at ***ADDRESS.1:

1. FRAUDULENT SIM CARD DUPLICATE (SIM SWAPPING) ON DATE 06-10-2022, 20:42 HOURS AT THE POINT OF SALE ORANGE STORE AT ***ADDRESS.1, MADRID.

On October 6, 2022, at 20:42 hours, a duplicate of the SIM card (...), IMSI number (...), belonging to the mobile number (...) owned by ORANGE customer (...) with ID number (...). According to the geolocation of the IMEIs of the devices used for the SIM duplicate, the impersonation occurred at the ORANGE store at ***ADDRESS.1 in Madrid owned by my represented party. To certify this geolocation, this party will formally request the commercializer ORANGE to provide this report.

Once it has been corroborated that the duplicate was carried out at the ORANGE store at ***ADDRESS.1 in Madrid owned by my represented party, the time sheets attached in the internal investigation report (Annex 1) show that during the time slot (06/10/2022) at 20:42 hours when the duplicate occurred, the only employee working in that store was the accused. Thus, it can be confirmed 100% that A.A.A. was at their corresponding workplace (point of sale) at the dates and times when the duplicate occurred.

(...)

2. FRAUDULENT SIM CARD DUPLICATE (SIM SWAPPING) ON DATE 07-10-2022, 20:36 HOURS AT THE POINT OF SALE ORANGE STORE AT ***ADDRESS.1, MADRID.

On October 7, 2022, at 20:36 hours, a duplicate of the SIM card with number (...), IMSI number (...), belonging to the mobile number (...) owned by ORANGE customer (...) with ID number (...). According to the geolocation of the IMEIs of the devices used for the SIM duplicate, the impersonation occurred at the ORANGE store at ***ADDRESS.1 in Madrid owned by my represented party. To certify this geolocation, this party will formally request the commercializer ORANGE to provide this report.

Once it has been corroborated that the duplicate was carried out at the ORANGE store at ***ADDRESS.1 in Madrid owned by my represented party, the time sheets attached in the internal investigation report (Annex 2) show that during the time slot (07/10/2022) at 20:36 hours when the duplicate occurred, the only employee working in that store was the accused. Thus, it can be confirmed 100% that A.A.A. was at their corresponding workplace (point of sale) at the dates and times when the duplicate occurred.

(...)

3. FRAUDULENT SIM CARD DUPLICATE (SIM SWAPPING) ON DATE 13-10-2022, 18:43 HOURS AT THE POINT OF SALE ORANGE STORE AT ***ADDRESS.1, MADRID.

On October 13, 2022, at 18:43 hours, a duplicate of the SIM card with number (...), IMSI number (...), belonging to the mobile number (...) owned by customer (...) with ID number (...). According to the geolocation of the IMEIs of the devices used for the SIM duplicate, the impersonation occurred at the ORANGE store at ***ADDRESS.1 in Madrid owned by my represented party. To certify this geolocation, this party will formally request the commercializer ORANGE to provide this report.

Once it has been corroborated that the duplicate was carried out at the ORANGE store at ***ADDRESS.1 in Madrid owned by my represented party, the time sheets attached in the internal investigation report (Annex 3) show that during the time slot (13/10/2022) at 18:43 hours when the duplicate occurred, the only employee working in that store was the accused. Thus, it can be confirmed 100% that A.A.A. was at their corresponding workplace (point of sale) at the dates and times when the duplicate occurred.

(...)

4. FRAUDULENT SIM CARD DUPLICATE (SIM SWAPPING) ON DATE 03-11-2022, 20:16 HOURS AT THE POINT OF SALE ORANGE STORE AT ***ADDRESS.1, MADRID.

On November 3, 2022, at 20:16 hours, a duplicate of the SIM card with number (...), IMSI number (...), belonging to the mobile number (...) owned by ORANGE customer (...) with ID number (...). According to the geolocation of the IMEIs of the devices used for the SIM duplicate, the impersonation occurred

at the ORANGE store at ***ADDRESS.1 in Madrid owned by my represented party. To certify this geolocation, this party will formally request the commercializer ORANGE to provide this report. It is noteworthy that this fraud was alerted by Orange to my represented party on November 21, 2022.

(...)

C/ Jorge Juan, 6

www.aepd.es

28001 – Madrid

sedeagpd.gob.es

9/63

Once it has been corroborated that the duplicate was carried out at the Orange store located at ***ADDRESS.1 in Madrid, owned by my client, the time sheets attached in the internal investigation report (Annex 4) show that during the time slot (03/11/2022) at 20:16 hours when the duplication occurred, the only employee working at that store was the accused. Thus, it can be confirmed 100% that A.A.A. was at their corresponding workplace (point of sale) on the dates and times when the duplication took place.

(...)

5. FRAUDULENT DUPLICATION OF SIM CARD (SIM SWAPPING) ON 15-11-2022, 20:16 HOURS AT THE POINT OF SALE ORANGE STORE

***ADDRESS.1

MADRID.

On November 15, 2022, at 20:46 hours, a duplication of the card with SIM Number (...), IMSI Number: (...) belonging to the mobile number (...), owned by the Orange customer (...) with ID number: (...). According to the geolocation of the IMEIs of the devices used for the SIM duplication, the impersonation occurred at the Orange store located at ***ADDRESS.1 in Madrid, owned by my client. To substantiate this geolocation, this party will request the commercializer Orange to provide said report.

Once it has been corroborated that the duplicate was carried out at the Orange store located at ***ADDRESS.1 in Madrid, owned by my client, the time sheets attached in the internal investigation report (Annex 5) show that during the time slot (15/11/2022) at 20:46 hours when the duplication occurred, the only employee working at that store was the accused. Thus, it can be confirmed 100% that A.A.A. was at their corresponding workplace (point of sale) on the dates and times when the duplication took place.

(...)

“SIXTH,- The narrated facts may constitute:

- POSSIBLE CRIME OF FRAUD USING ELECTRONIC MEANS. (248.2 CP)
- AND/OR POSSIBLE CRIME OF THEFT (234 CP) AND/OR POSSIBLE UNLAWFUL APPROPRIATION (235 CP AND FOLLOWING)
- AND/OR POSSIBLE IDENTITY THEFT WITH USURPATION OF CIVIL STATUS (401 CP).
- AND/OR POSSIBLE CRIME OF COMPUTER INTRUSION AND INTERCEPTION OF COMPUTER DATA TRANSMISSIONS (197 BIS CP)”

(...)

C/ Jorge Juan, 6

www.aepd.es

28001 – Madrid

sedeagpd.gob.es

10/63

THIRTEENTH: ORANGE has submitted in its written allegations to the initiation agreement of this sanctioning file, dated December 21, 2023, a “GDPR REPORT. AUDIT OPINION. APPLICATION OF PRIVACY PRINCIPLES BY DESIGN AND BY DEFAULT,” dated December 18, 2023, and in the conclusions, it can be observed:

“(...)”

FOURTEENTH: ORANGE has submitted in its written allegations to the initiation agreement of this sanctioning file, a document titled "Procedure. Data Protection by Design and by Default," with an initial version dated 04/04/2018, and in its version 2.0 dated November 18, 2019, it can be observed in section 4:

"4. Data Protection by Design

In compliance with what is stated in the Privacy by Design Guide published by the AEPD, ORANGE is obliged to adopt privacy design strategies aimed at applying the appropriate technical and organizational measures from the first phase of development of an information system or a new project or service that involves data processing, and throughout its execution, as well as to verify and manage control over the collection, use, and disclosure of personal data processed from the first phase of personal data processing.

(...)

5. Data protection by default.

(...).

6. Implementation of appropriate measures

(...).

7. Verification of compliance

(...):

(...)

THIRD: The appealing party submitted on November 25, 2024, to this Spanish Agency for Data Protection, a request for reconsideration, basing it fundamentally on:

1.- CRIMINAL PREJUDICIALITY.

2.- ON THE FACTUAL ASSUMPTION.

C/ Jorge Juan, 6

www.aepd.es

28001 – Madrid

sedeagpd.gob.es

11/63

i) On the consideration of the SIM card as personal data

ii) On the execution of banking operations

iii) On the relationship of the perpetrators of the criminal act with ORANGE

3.- ON THE CRIMINAL ACTION OF THE AGENTS.

4.- NON-EXISTENCE OF LACK OF LEGITIMATION IN THE PROCESSING OF PERSONAL DATA BY ORANGE.

5.- ON THE CORRECT IMPLEMENTATION OF PRIVACY BY DESIGN AND BY DEFAULT.

i) On the risk analysis for rights and freedoms

6.- ON THE EXISTENCE OF A CONCUR OF INFRINGEMENTS.

7.- ON THE INADMISSIBILITY OF OBJECTIVE LIABILITY.

8.- ON THE MEASURES ADOPTED AND IMPLEMENTED BY ORANGE.

I) Measures implemented by ORANGE to prevent the commission of fraud arising from the identity theft of its client.

II) Measures implemented by ORANGE to prevent the commission of fraud arising from the impersonation of agents and/or employees of ORANGE.

9.- ON THE LACK OF PROPORTIONALITY OF THE PROPOSED SANCTION.

LEGAL GROUNDS

I

Competence

The Presidency of the Spanish Agency for Data Protection is competent to resolve the present appeal, in accordance with the provisions of Article 123 of Law 39/2015, of October 1, on the Common Administrative Procedure of Public Administrations (hereinafter, LPACAP) and Article 48.1 of Organic Law 3/2018, of December 5, on Personal Data Protection and Guarantee of Digital Rights (hereinafter, LOPDGDD).

II

Response to the allegations presented

In relation to the statements made by the appellant, reiterating basically the allegations already presented throughout the sanctioning procedure, it should be noted that all of them have already been analyzed and dismissed in the Legal Grounds III of the contested Resolution, as transcribed below:

1.- CRIMINAL PREJUDICIALITY.

Regarding this allegation, it should be noted that it has already been addressed in the Resolution of the sanctioning procedure as follows:

In relation to this issue, this Agency considers it necessary to point out that, in the present sanctioning file, however, there is no triple identity necessary to apply Article 77.4 of Law 39/2015 regarding subject, fact, and basis between the administrative infringement being assessed and the possible criminal infringements that could arise from the claim filed before the jurisdictional body mentioned by ORANGE, to the extent that the infringing subject is not the same.

Thus, ORANGE is the responsible subject in the present sanctioning procedure, while the criminally responsible party would be the employee who proceeded to duplicate the SIM card, as stated in the claim filed by ORANGE in its written allegations.

In this regard, the Judgment of the National Court of April 27, 2012 (rec. 78/2010) is very enlightening, in which the Court states in its Second Legal Ground the following in response to the appellant's claim that the AEPD has violated Article 7 of R.D. 1398/1993 (a regulation that was in force until the entry into force of the LPACAP):

"In this sense, Article 7 of Royal Decree 1398/1993, of August 4, on the procedure for the exercise of sanctioning power, only provides for the suspension of the administrative procedure when the effective and real existence of a criminal procedure is verified, if it is considered that there is identity of subject, fact, and legal basis between the administrative infringement and the criminal infringement that may correspond.

However, for the concurrence of criminal prejudiciality, it is required that it directly conditions the decision to be made or that it is essential to resolve, prerequisites that do not occur in the case examined, in which there is a separation between the facts for which sanctions are imposed in the resolution now contested and those that the appellant invokes as possible criminal offenses. Thus, even if criminal proceedings had been initiated in this case, regarding the facts now in dispute, against the distributing company, the truth is that both the sanctioning conduct and the legal good protected are different in each case (contentious-administrative and criminal). In the criminal sphere, the legal good protected is a possible documentary falsification and fraud, while in the administrative sphere, it is the right of disposition of one's personal data by its owner, which is why such objection from the defendant must be rejected."

C/ Jorge Juan, 6

www.aepd.es

28001 – Madrid

sedeagpd.gob.es

13/63

At this point, it should be noted that ORANGE, throughout its appeal, merely denies the arguments made in the resolution and forgets that the object of this file is the issuance of a duplicate SIM card in the name of the respondent party, which had not been requested, by its operator ORANGE. Therefore, the issue raised by ORANGE cannot succeed and must be rejected.

2.- ON THE FACTUAL ASSUMPTION.

i) On the consideration of the SIM card as personal data.

This issue has been addressed in the resolution now being appealed in the following manner:

"With regard to this issue, and as already included in the initiation agreement of the present sanctioning file, the SIM card is a card that is inserted within the mobile terminal. It is a smart card, in physical format and of small dimensions, which contains a chip that stores the service key of the subscriber or user used to identify themselves to the network, that is, the mobile phone line number of the customer MSISDN (Mobile Station Integrated Services Digital Network), as well as the personal identification number of the subscriber IMSI (International Mobile Subscriber Identity), but it can also

provide other types of data such as information about the phone directory or the list of calls and messages.

Moreover, the issuance of a duplicate SIM card involves the processing of the personal data of its holder since any person whose identity can be determined, directly or indirectly, particularly by means of an identifier (Article 4.1 of the GDPR), will be considered an identifiable natural person.

Therefore, the SIM card identifies a phone number, and this number in turn identifies its holder. In this regard, the Judgment of the CJEU in case C-101/2001 (Lindqvist) of November 6, 2003, paragraph 24, Rec. 2003 p. I-12971 states: "The concept of 'personal data' used in Article 3(1) of Directive 95/46 includes, according to the definition in Article 2(a) of that Directive, 'any information relating to an identified or identifiable natural person'. This concept undoubtedly includes a person's name along with their phone number or other information relating to their working conditions or hobbies."

In summary, both the data processed to issue a duplicate SIM card and the SIM card (Subscriber Identity Module) that unequivocally identifies the subscriber on the network are personal data, and their processing must be subject to data protection regulations.

In this regard, the Judgment of the National Court of February 8, 2024, states:

"We must start from the premise that the issuance of a duplicate SIM card involves the processing of the personal data of its holder since, according to Article 4.1..."

C/ Jorge Juan, 6

www.aepd.es

28001 – Madrid

sedeagpd.gob.es

14/63

of the GDPR, an identifiable natural person is considered to be any person whose identity can be determined, directly or indirectly, in particular by means of an identifier. Within the mobile terminal, the SIM card is inserted. It is a smart card in a physical format and of small dimensions, which contains a chip that stores the subscriber's service key used to identify themselves to the network, namely, the customer's mobile line number MSISDN (Mobile Station Integrated Services Digital Network) as well as the subscriber's personal identification number IMSI (International Mobile Subscriber Identity), but it can also provide other types of data such as information about the phone directory or call and message logs.

And as highlighted in the contested resolution, since 2007, in Spain, in accordance with the Single Additional Provision of Law 25/2007, of October 18, on the retention of data related to electronic communications and public communications networks, it is required that the holders of all SIM cards, whether prepaid or contract, be duly identified and registered. Therefore, when obtaining a duplicate of the SIM card, the person requesting it must also identify themselves and their identity must match that of the holder.

Furthermore, the Judgment of the National Court dated February 9, 2023, also states the following:

"Indeed, the SIM card is a smart card that is inserted into the mobile terminal, which contains a chip that stores the subscriber's service key used to identify themselves to the network.

Thus, the Attorney General's Office indicates, in a report from July 2016, cited by the contested resolution: 'According to European standards related to digital cellular telecommunications systems, established by the European Telecommunications Standards Institute (ETSI), a fully operational mobile communications device, colloquially referred to as a "Mobile Phone," materially consists of two essential elements. Firstly, the terminal (...). Secondly, the user identification module, better known as the "SIM card" (Subscriber Identity Module). This SIM card is interchangeable between the different mobile terminals available on the market and contains its digital chip the necessary information to identify and authenticate the subscriber, including the International Mobile Subscriber Identity (IMSI), which unequivocally identifies the subscriber on the cellular network. Without a valid IMSI, telephone services will not be accessible, except in the case of an emergency call.'

Therefore, the IMSI is the identification code in the cellular communications network and is fundamental for identifying the subscriber, and as it is stored on the SIM card, whoever has that card (the impersonator) has the stored IMSI. Furthermore, as soon as the impersonator inserts the SIM into a terminal and powers it on, the IMSI will be accessed and exchanged with the network.

C/ Jorge Juan, 6
www.aepd.es
28001 – Madrid
sedeagpd.gob.es
15/63

In this context, insofar as the IMSI installed on the SIM card allows for the singularization of an individual and therefore their identification, it must be considered as personal data, according to Article 4 of the GDPR, which defines it as “any information relating to an identified or identifiable natural person (the data subject); an identifiable natural person is one who can be identified, directly or indirectly, in particular by reference to an identifier, such as a name, an identification number, location data, an online identifier, or one or more factors specific to the physical, physiological, genetic, mental, economic, cultural, or social identity of that person.”

That is to say, the improper issuance of a mobile phone SIM card of a person to a third party who impersonates their identity allows that third party to access the confidential information stored on that card and to the line of the legitimate holder of the SIM card, resulting in a clear loss of confidentiality since the data is transmitted to a third party unlawfully.

It should be noted that in Spain, since 2007, under the Sole Provision of Law 25/2007, of October 18, it is required that the holders of all SIM cards be duly identified and registered. This is important because the identification of the subscriber will be essential to activate the SIM card, which will mean that when obtaining a duplicate of it, the person requesting it must identify themselves and that their identity must match that of the holder.

In summary, both the personal data (name, surname, and ID number) that are processed to issue a duplicate of the SIM card, as well as the SIM card itself that unequivocally identifies the subscriber on the network, are personal data...”

ii) Regarding the execution of banking operations.

In relation to this allegation, it should be noted that, despite ORANGE's statements, in which it claims that this Agency has not assessed them, they have already been addressed in the following manner in the resolution of the sanctioning file:

“In this regard, concerning the fact of granting the duplicate of the SIM card the ability to allow the execution of banking operations, it should be noted that ORANGE itself, when filing the complaint against the agent who issued the duplicate of the SIM card that led to the opening of this sanctioning file, has defined the concept of SIM SWAPPING as follows:

‘SIM Swapping is a cyberattack that consists of impersonating the identity of a person before their telephone service provider and requesting a duplicate of the SIM card of their mobile phone in order to access their online banking and operate with it, receiving SMS with the confirmation code for banking operations on that new SIM, proceeding to divert the money from...’

C/ Jorge Juan, 6
www.aepd.es
28001 – Madrid
sedeagpd.gob.es
16/63

the current account of the impersonated person to another property of the criminals.

The victim, as is the case here, only becomes aware of the situation when they lose coverage on their mobile phone, and no matter how much they restart the device or try to find coverage, they cannot do so because, upon the activation of the new duplicated SIM that the cybercriminals request from the telecommunications company, the SIM that is in the victim's phone stops functioning.”

In this regard, ORANGE itself confirms the concept of SIM Swapping, which aims to access online banking by receiving SMS with the confirmation code for banking operations on the new SIM, and proceed to divert money from the current account of the impersonated person to another account owned by the criminals. Therefore, in this aspect, there is no doubt about the concept of SIM Swapping and the reasons why duplicates of SIM cards are requested.

Furthermore, in the present case, regarding the infringement of Article 6 of the GDPR, what is being analyzed is the duplication of a SIM card owned by the claimant and without their consent, in a store

owned by ORANGE.

Regarding the infringement of Article 25 of the GDPR, ORANGE, for the establishment of appropriate measures to the risk, must evaluate the possible risks to the rights and freedoms of individuals, among which is the risk that customers suffer the well-known SIM Swapping attack through the fraudulent obtaining of a duplicate of their SIM card, which leads to the consequent loss of control over their own personal data and possible financial losses. All of this is independent of the liability that financial entities may incur if they acted with a lack of diligence.

On the other hand, ORANGE also refers to the fact that, in the initial agreement, erroneous associations are made to aggravate the factual situation by granting the duplicate of the SIM card the ability to allow the execution of banking operations, omitting the prior step whereby the wrongdoers must obtain and be able to use the banking credentials of the claimant to identify themselves and carry out the identity theft before the financial entity.

It adds that this AEPD does not mention the role played by financial entities in these cases, and there is no record that sanctioning procedures have been initiated against them.

Regarding the responsibility of financial entities, it should be noted that the PSD2 Directive applies to payment services provided within the Union (Article 2), and not to ORANGE, but it is also true that the issuance of a duplicate SIM card in favor of a third party who is not the line holder provides the impersonators with control over the telephone line, and therefore...

C/ Jorge Juan, 6

www.aepd.es

28001 – Madrid

sedeagpd.gob.es

17/63

thus, from the SMS directed to the phone linked to the initial SIM card and in this way to be able to access the authentication code of the transaction.

According to Article 4.30 of the Directive, "strong authentication" is based on the use of two or more elements categorized as knowledge (something only the user knows), possession (something only the user possesses), and inherence (something that is the user). These elements or factors are independent of each other and, therefore, the compromise of one does not undermine the reliability of the others.

The rationale is very simple: the more elements there are to verify the identity of the user, the more secure the transaction is.

In these cases, the impersonator must first enter the username and password in the application or on the website of the payment service provider or online banking. Secondly, to complete the transaction or electronic management they wish to carry out, the impersonator will receive, usually via SMS, an alphanumeric verification code on the mobile phone linked to that profile. This code has a limited time validity and is for one-time use only, meaning it is generated solely for that specific transaction and for a limited time. Once the verification code is entered, the transaction would be carried out and completed. It is presumed that only the user has the mobile device in their possession (this would be the "something they have"), so by receiving the verification code on that mobile phone via SMS, their identity would be doubly authenticated. Therefore, it would not be sufficient for impersonators to know the username and password with which the victim identifies themselves; they would also need to intercept that confirmation code. Consequently, to carry out an unauthorized transfer, transaction, or purchase, that is, to commit the cyber fraud, the cybercriminal must illegitimately access the verification codes associated with each of those operations sent by the banking entity via SMS, and the most common way to do this is by obtaining a duplicate of the SIM card.

Therefore, it is necessary to execute two completely different but complementary actions.

First, the access data to the online banking or payment provider owned by the person to be defrauded must be obtained, if we focus on the search for asset enrichment.

And, secondly, a duplicate of the SIM card owned by the person to be defrauded must be obtained in order to gain access to the confirmation SMS that the client will receive on their mobile terminal as double-factor authentication.

Well, in the last of these actions - obtaining the duplicate - is where the facts subject to this procedure

have focused, and not on the events that occurred in the first phase, which, as is obvious, are outside the responsibility attributed to ORANGE in this procedure.

On the other hand, ORANGE states that the AEPD intends to sanction SIM SWAPPING frauds without addressing or analyzing the specific factual situation, the associated harm, or the derived responsibilities, without taking into account the diligence displayed by ORANGE in its actions and in the adoption of security measures. It adds that the AEPD fails to assess the documentation provided, establishing a generic discourse to legitimize a violation of data protection regulations.

However, regarding this issue, it is necessary to refer to the procedural moment in which ORANGE presents these allegations. In this sense, in accordance with the provisions of Article 64 of Law 39/2015, on the Common Administrative Procedure of Public Administrations, referring to the "Agreement to initiate sanctioning procedures," subsection 2 establishes:

"2. The initiation agreement must contain at least:

- a) Identification of the person or persons allegedly responsible.
- b) The facts that motivate the initiation of the procedure, its possible qualification, and the sanctions that may correspond, without prejudice to what results from the instruction.
- c) Identification of the instructor and, where applicable, the secretary of the procedure and the norm that attributes such competence to them, with express indication of the recusal regime applicable to them.
- d) Competent body for the resolution of the procedure and the norm that attributes such competence, indicating the possibility that the alleged responsible party may voluntarily acknowledge their responsibility, with the effects provided for in Article 85.
- e) Provisional measures that have been agreed upon by the competent body to initiate the sanctioning procedure, without prejudice to those that may be adopted during it in accordance with Article 56.
- f) Indication of the right to make allegations and to be heard in the procedure and the deadlines for exercising these rights, as well as an indication that, if no allegations are made within the stipulated period regarding the content of the initiation agreement, it may be considered a proposal for resolution when it contains a precise pronouncement regarding the attributed responsibility."

Therefore, the initiation agreement of the present sanctioning procedure contains all the pronouncements required by the applicable regulations.

C/ Jorge Juan, 6

www.aepd.es

28001 – Madrid

sedeagpd.gob.es

19/63

Notwithstanding the above, the allegation raised by ORANGE cannot be taken into account, insofar as the factual assumption is indeed contemplated and assessed when determining the sanction associated with the infringements of Articles 6 and 25 of the GDPR, as stated in section a) of Article 83 of the GDPR.

Regarding ORANGE's diligence, it should be noted that this aspect has been evaluated as an aggravating factor in the infringement of Article 25 of the GDPR, so it has been analyzed. In relation to the measures adopted subsequently, it should be pointed out that they are positively assessed, but they do not determine that there has been no infringement of Article 25 of the GDPR.

Finally, the assertion made by ORANGE regarding this Agency using generic language, or that the submitted documentation is not evaluated, cannot be taken into account, as can be observed in this document and in the large number of established facts.

iii) On the relationship of the authors of the criminal act with ORANGE.

This issue has also been addressed in the following manner in the contested resolution:

"However, regarding the statements that the agents of the data processor did not follow the instructions of ORANGE as the data controller, it should be noted that the Guidelines 7/2020 of the EDPB determine that:

"30 Following the line of the fact-based approach, the word 'determine' means that the entity that truly exercises decisive influence over the purposes and means of processing is the controller. Generally,

the processing contract establishes who is the determining party (the data controller) and who is the party that follows the instructions (the data processor). Even when the data processor offers a service that is previously defined in a specific way, it must present the data controller with a detailed description of the service, and the data controller must make the final decision on the approval of how the processing will be carried out and request any changes it deems necessary. Furthermore, the data processor cannot modify, at a later time, the essential elements of the processing without the approval of the controller.

39. The question is where to draw the line between the decisions reserved for the data controller and those that can be left to the discretion of the processor. It is evident that decisions regarding the purpose of the processing must always correspond to the controller.

40. As for the determination of the means, a distinction should be made between essential and non-essential means. Essential means are traditionally and inherently reserved for the data controller. These must be mandatorily determined by the data controller."

C/ Jorge Juan, 6
www.aepd.es
28001 – Madrid
sedeagpd.gob.es
20/63

although the determination of non-essential means may also be left in his hands. Essential means are those closely linked to the purpose and scope of the processing, such as the type of personal data processed ("What data will be processed?"), the duration of the processing ("How long will the data be processed?"), the categories of recipients ("Who will have access to the data?"), and the categories of data subjects ("To whom do the processed personal data belong?"). In addition to being related to the purpose of the processing, essential means are closely linked to the question of whether the processing is lawful, necessary, and proportionate. Non-essential means are related to more practical aspects of the processing itself, such as the choice of a particular type of hardware or software or the decision on the details of security measures, which may be left to the data processor.

41. Although decisions regarding non-essential means may be left to the data processor, the controller must still stipulate certain elements in the contract with the processor: for example, regarding the security requirement, all measures required under Article 32 of the GDPR may be mandated. The contract must also establish that the processor will assist the controller in ensuring compliance with, for example, the provisions of Article 32. In any case, the data controller remains responsible for implementing appropriate technical and organizational measures to ensure and be able to demonstrate that the processing is in compliance with the Regulation (Article 24). To this end, the controller must take into account the nature, scope, context, and purposes of the processing, as well as the risks to the rights and freedoms of natural persons. For this reason, the data controller must have complete information about the means used, as this will enable them to make an informed decision in this regard. To demonstrate the legality of the processing, it is advisable to document, in the contract or another legally binding instrument between the controller and the processor, at least the necessary technical and organizational measures.

(...)

80. Secondly, the processing must be carried out on behalf of a data controller, but not under their direct authority or control. Acting "on behalf of" someone means serving the interests of another and refers to the legal concept of "delegation." In the case of data protection regulations, the role of the data processor is to apply the instructions given by the data controller, at least regarding the purposes of the processing and the essential elements of the means. The legitimacy of the processing under Article 6 and, if applicable, Article 9 of the Regulation derives from the activity of the controller, and the processor must only process the data following the instructions given by the controller. Nevertheless, as previously indicated, the instructions of the data controller may leave some discretion regarding how best to serve their interests, allowing the processor to choose the most suitable technical and organizational means.

C/ Jorge Juan, 6
www.aepd.es

21/63

81. Acting “on behalf of” someone also means that the processor cannot carry out the processing for their own purposes. As stipulated in Article 28, paragraph 10, the data processor will violate the GDPR when they do not adhere to the controller's instructions and begin to determine their own purposes and means of processing. In such cases, the data processor will be considered responsible for that processing and may be sanctioned for failing to comply with the controller's instructions.

As previously noted, the CJEU ruling states that “a data controller is responsible not only for all processing of personal data that they carry out themselves but also for processing carried out on their behalf; an administrative fine may be imposed on that controller under Article 83 of the GDPR in a situation where personal data is subject to unlawful processing and it is not the controller, but a processor they have engaged, who has carried out the processing on their behalf.”

In the present case, and as recorded in the Findings of Fact of this Resolution, the duplication of the SIM card occurs at an ORANGE establishment owned by the company “TOWER PHONE, S.L.,” which acts as the data processor for ORANGE.

Reference is also made to the franchise contract between the two entities, dated April 1, 2022, in which it could be verified that:

II. “(…)”

V. (…).

(…)

(…)

(…)

(…)

In addition to all this, it should be noted, as previously mentioned, that the customer is, at all times, contracting the telephone services with ORANGE, since, in accordance with all the aforementioned and as stated in the franchise contract, it is ORANGE as the data controller that determines the purpose and means of the processing carried out for the exercise of the activity, and who actually provides the telephone service.

Therefore, based on the above, it is appropriate to dismiss this allegation from ORANGE.”

3.- ON THE CRIMINAL ACTION OF THE AGENTS.

C/ Jorge Juan, 6

www.aepd.es

28001 – Madrid

sedeagpd.gob.es

22/63

This allegation was addressed in the resolution now being appealed in the following manner:

“With this allegation, ORANGE is attempting to have this case treated differently from other cases of SIM SWAPPING, given that the case that motivated the opening of this sanctioning procedure would consist of a new variant of a criminal offense.

However, this issue has already been addressed in the allegations to the initiation agreement to which we refer from here, in section Third: regarding ORANGE's role as a victim, in the following manner:

ORANGE, with this allegation, highlights that it involves the issuance of a duplicate SIM card carried out differently from other cases, in that it was performed by two sales representatives from the company's point of sale, who were consequently acting on behalf of ORANGE.

Before continuing with the rest of the arguments presented by ORANGE, this AEPD wishes to state that the complaint filed with the Investigating Court is directed against A.A.A., for possible crimes of:

- possible crime of fraud using electronic means (238.2 CP)
- and/or possible crime of theft (234 CP) and/or possible misappropriation (235 CP and following)
- and/or possible identity theft with usurpation of civil status (401 CP)
- and/or possible crime of computer intrusion and interception of computer data transmissions (197 bis CP)

- any other that may be appreciated from the instruction of the present case.

In the facts of the complaint filed, it is stated that the accused began working at the workplace located at ***ADDRESS.1 in Madrid, on July 12, 2021. The accused worked until December 11, 2022.

Furthermore, in Fact four of the complaint, which discusses the reported events, there are up to 5 impersonations carried out by the ORANGE employee from the ***ADDRESS.1 store in Madrid.

On the other hand, in Fact three of the complaint, the concept of SIM SWAPPING is discussed as follows:

“First of all, it is important to explain what the facts reported here (SIM Swapping) consist of, carried out by the accused B.B.B. on at least November 14, 17, and 21, 2022, at his workplace, the ORANGE point of sale located at ***ESTABLISHMENT.1 in Madrid (***ADDRESS.1).”

C/ Jorge Juan, 6

www.aepd.es

28001 – Madrid

sedeagpd.gob.es

23/63

Therefore, although in its allegations ORANGE speaks of two workers from the same store, it is clearly observed that two workers from two different stores have been involved in a case like the one reported by the claiming party. Furthermore, if we take into account the content of the complaint, in the ORANGE store located at ***ADDRESS.1, 5 individuals were affected, while in the store located at ***ESTABLISHMENT.1 in Madrid, individuals were affected (...).

Once this clarification is made, in the sense that it was not two workers from the same store who acted incorrectly, but rather workers providing their services in two different stores, and that, from the content of the complaint filed by ORANGE with the Investigating Court, it is clearly deduced that at least 8 people were affected, ORANGE's statements regarding the impossibility of demanding total capacity for the detection and prevention of such criminal acts must fall.

In this regard, the action that has led to the occurrence of an event such as that reported is due to the fact that the procedure that ORANGE had implemented for issuing a duplicate SIM card, (...)

This is explained by ORANGE in its written allegations to the initiation agreement, dated December 21, 2023, submitted to this Agency, in such a way that, as ORANGE states, “in the case at hand, ORANGE agents used (...), which is why, when entering it into the system of (...).

Thus, for this type of documentation reading errors, ORANGE's Protocol establishes that, while a notice must be generated to the Risk Analysis Group, it allows commercial agents for specified cases (...). This is due to the necessary opening of said manual process within an absolutely automated system that must allow the commercial act (...).

It is for this reason that in the present sanctioning procedure, the infringement of Article 25 of the GDPR has been charged, since it states that the data controller, taking into account the state of the art, the cost of application, and the nature, scope, context, and purposes of the processing, as well as the risks of varying probability and severity that the processing entails for the rights and freedoms of natural persons, must apply, both at the time of determining the means of processing and at the time of the processing itself, appropriate technical and organizational measures, in order to comply with the requirements of this Regulation and protect the rights of the data subjects.

This article imposes an obligation to design internal procedures at the time of determining the means of processing and to apply those procedures at the time of processing, to effectively ensure compliance with data protection requirements.

C/ Jorge Juan, 6

www.aepd.es

28001 – Madrid

sedeagpd.gob.es

24/63

ORANGE, when communicating the procedure it has implemented for the issuance of duplicate SIM cards, has informed that there are cases in which it can proceed to (...).

The principle of data protection by design imposes that, from the earliest stages of planning a data

processing activity, this principle must be considered: the data controller, from the moment a potential processing of personal data is designed and planned, must determine all the elements that make up the processing, for the purpose of effectively applying the principles of data protection, integrating the necessary guarantees in the processing with the ultimate goal of, in compliance with the provisions of the GDPR, protecting the rights of the data subjects.

With the system that ORANGE had implemented, as stated in its written allegations to the initiation agreement of the present sanctioning procedure, dated December 21, 2023, the agents were able to use a (...) that can arise from the delivery of a valid SIM card to a third party without the consent of its holder. Thus, as ORANGE claims, by introducing the agents (...). For this type of errors, as they state, the ORANGE Protocol establishes that, although a notice must be generated to the Risk Analysis Group, it allows commercial agents for cases (...). According to ORANGE, this is due to the necessary opening of said manual process within an absolutely automated system that must allow (...). In this context, ORANGE articulated a protocol that had as its main objective the execution of the commercial act, but that did not contemplate the risk of issuing and delivering a SIM card to a person other than its holder. The notice to the Risk Analysis Group is manifestly ineffective, as it did not succeed in detecting the impersonation, at least in the cases known to this Agency through the present procedure. Therefore, from the design of the processing, there were no measures from Article 25 of the GDPR to verify that the information entered was not erroneous, and to check that the request for a duplicate card was being made by the holder of the line to whom the delivery was also being made.

This implies that ORANGE would not have adequately identified and analyzed the risks that a manual process of duplicate SIM card issuance entails for the rights and freedoms of individuals, nor anticipated or applied from the design the appropriate technical and organizational measures, to effectively apply the data protection principles required by Article 25 of the GDPR.

The fundamental right to data protection also includes that data controllers integrate data protection into the design of personal data processing, from its inception and throughout the entire processing cycle, establishing appropriate policies for compliance with this principle and the protection of individuals' rights, and that is precisely what ORANGE did not do and what is being questioned in this sanctioning procedure, since the mechanism it had implemented.

C/ Jorge Juan, 6
www.aepd.es
28001 – Madrid
sedeagpd.gob.es
25/63

ORANGE had not even anticipated the obligation to issue duplicates of SIM cards introducing (...), as ORANGE acknowledges in its written submissions.

In any case, despite ORANGE's statements regarding the fact that the agents took advantage of their knowledge of the system to commit a criminal act, in its written submissions they state that "since December 14, 2022, ORANGE has proceeded to the precautionary suspension of the option that allows point-of-sale agents to (...)." That is to say, that despite everything stated and the defense made of the system that was implemented, it has decided to suspend the system that allows the issuance of a duplicate SIM card using (...).

ORANGE states that it had diligent security measures and procedures in place, and as a consequence, it has been the criminals who have evolved, which would prove that it did have an adequate design of privacy.

It adds that the emergence of these practices would have been highlighted in the "Telecom Anti-Fraud Committee" held in March 2023, and that as a consequence of agents being corrupted and being able to engage in criminal activities, a new risk assessment attributed to this threat has been carried out, providing a risk matrix as document No. 1, in which an element related to SIM SWAPPING can be observed, but which is related to Phishing. And nothing related to employee fraud is mentioned. It also lists as an element "Fraudulent Use of Data by 3rd Parties/ Payment Fraud."

ORANGE states that this matrix can be compared with that provided as document No. 12 in the allegations to the initiation agreement. This document 12 is titled "2023 Non-Telco Fraud Risk map. Key risk" and it also includes a section related to "Fraudulent use of Data-3rd Parties" and in this point

“(…)”

However, the risk derived from employees potentially using their credentials to commit criminal acts is not included in any of these tables either. The risk referred to as “Fraudulent use of Data-3rd parties” is drafted in a generic manner, and this does not imply that the risk referred to by ORANGE was analyzed and evaluated in light of the measures implemented by ORANGE.

At this point, ORANGE insists that it cannot be interpreted that allowing a store agent to make decisions on certain issues can be equated to a breach of the GDPR, because it conflicts with the very regulation contained therein, where it would be considered that the risk lies in the adoption of automated decisions without human intervention. And it added that the purpose of the agent's intervention was to prevent that, in specific and defined cases, (...) it prevents the interested party from accessing a contracted service.

C/ Jorge Juan, 6
www.aepd.es
28001 – Madrid
sedeagpd.gob.es

26/63

ORANGE continues to state that the Agency categorizes the parameterization of a (...) as a violation of Article 25.

In relation to this issue, it is necessary to point out that this matter has also been addressed in the proposed resolution, in the sense that ORANGE has implemented a system for the issuance of SIM cards in which (...), but not only, as ORANGE states, when the (...).

(...).

In light of these circumstances, ORANGE states that, (...). As ORANGE points out “(…).”

However, as has been demonstrated, (...).

For all the above, this allegation must be dismissed.

4.- NON-EXISTENCE OF LACK OF LEGITIMACY IN THE PROCESSING OF PERSONAL DATA BY ORANGE.

This allegation by ORANGE has already been addressed in the resolution now being appealed, as follows:

“ORANGE, with this allegation, wants to insist that the facts that have motivated the opening of the sanctioning file have been carried out by employees of one of its data processors, and understands that this Agency intends to hold ORANGE responsible for the actions of these agents, regardless of whether this conduct may constitute a criminal offense.

This issue, however, has already been addressed in the second allegation, section 3 of Foundation III. It should be recalled that what is being judged in this sanctioning procedure regarding the infringement of Article 6 of the GDPR is the fact that the data of the complaining party have been processed through the issuance of a duplicate of their SIM card, without any basis of legitimacy being present.

To issue the duplicate (...), which demonstrates that ORANGE did not have their consent. The SIM card has been issued in the name of ORANGE, which means that ORANGE is responsible for the processing and, as such, responsible for ensuring that the processing carried out on its behalf is based on one of the circumstances that legitimizes the processing of personal data.

It is ORANGE that must respond for the breach in data protection matters, without prejudice to any subsequent actions it may take.”

Therefore, in light of all the above, this allegation should be rejected.

C/ Jorge Juan, 6
www.aepd.es
28001 – Madrid
sedeagpd.gob.es

27/63

5.- ON THE PROPER IMPLEMENTATION OF PRIVACY BY DESIGN AND BY DEFAULT.

In relation to this statement, it should be noted that ORANGE merely indicates that it would comply with the provisions of Article 25 of the GDPR. It adds that the procedure for duplicating SIM cards has

already been analyzed in numerous cases that have been archived, and that at no time was there any mention of a potential non-compliance with Article 25. To this end, it refers to a series of cases that would have been archived by this Agency. In this regard, it is noteworthy that ORANGE intends for the present SIM SWAPPING case to be treated differently from the others in some parts of its appeal, only to later make this allegation based on the doctrine of acts of its own and that, consequently, based on the archived cases concerning the entity, it should be understood that it complies with the provisions of the aforementioned article.

This statement cannot be taken into account, to the extent that, by that reasoning, all claims against ORANGE should be archived, and, in addition, it should be noted that those cases mentioned are not related to the alleged SIM SWAPPING, and one of them does not even refer to ORANGE.

Furthermore, it should be noted that ORANGE reproduces almost in the same manner the allegations made throughout the sanctioning procedure, and this issue has already been addressed in the resolution now being appealed, in which a thorough analysis was made of why Article 25 was not complied with, as follows:

“ORANGE wishes to state that, based on the statements collected in the proposed resolution, privacy by design would have been taken into account, depending on the documentation submitted, the design of protocols, and the establishment of measures aimed at ensuring compliance with the principles of data protection.

It should be noted that Article 25 of the GDPR falls within the general obligations established for the data controller in Chapter IV of the GDPR, imposing a design obligation at the moment of determining the means of processing, which must effectively ensure compliance with the principles of data protection.

The GDPR requires controllers to establish the necessary technical and organizational measures throughout the entire lifecycle of the processing, from the initial moment when the processing is defined and the means are determined, as well as during its implementation and regular operation.

Data protection by design aims to apply the principles of data protection in the design processes of the systems and procedures of the organization on which the data processing relies, with a primarily preventive purpose aimed at avoiding potential...

C/ Jorge Juan, 6

www.aepd.es

28001 – Madrid

sedeagpd.gob.es

28/63

damages to individuals as well as, collaterally, the harm that the modification or redesign of the systems in which the processing takes place could entail for the organization, once developed and implemented, as a consequence of identifying design errors that could cause harm or detriment to the data subjects and their rights and freedoms.

In this regard, Recital 78 of the GDPR states:

The protection of the rights and freedoms of natural persons with regard to the processing of personal data requires the adoption of appropriate technical and organizational measures to ensure compliance with the requirements of this Regulation. In order to demonstrate compliance with this Regulation, the data controller must adopt internal policies and implement measures that specifically comply with the principles of data protection by design and by default. Such measures may consist, among others, of minimizing the processing of personal data, pseudonymizing personal data as soon as possible, providing transparency regarding the functions and processing of personal data, allowing data subjects to monitor the processing of data, and enabling the data controller to create and improve security elements. When developing, designing, selecting, and using applications, services, and products that are based on the processing of personal data or that process personal data to fulfill their function, producers of products, services, and applications should be encouraged to take into account the right to data protection when developing and designing these products, services, and applications, and to ensure, with due regard to the state of the art, that data controllers and processors are in a position to comply with their obligations regarding data protection. The principles of data protection by design and by default must also be considered in the context of public contracts.

Specifically, in light of Recital 78 of the GDPR, the principle of data protection by design is the key to be followed by the data controller to demonstrate compliance with the GDPR, as the data controller must adopt internal policies and implement measures that specifically comply with the principles of data protection by design and by default. The principle of privacy by design is a manifestation of the shift from reactivity to proactivity and a direct expression of the risk-based approach imposed by the GDPR. Part of the proactive responsibility requires that this principle be considered from the earliest stages of planning a processing operation: the data controller, from the moment a potential processing of personal data is designed and planned, must determine all the elements that make up the processing, in order to effectively apply the principles of data protection, integrating the necessary safeguards into the processing with the ultimate aim of, in compliance with the provisions of the GDPR, protecting the rights of the data subjects.

Thus, regarding the risks that may be present in the processing, the data controller will carry out an analysis and detection exercise.

C/ Jorge Juan, 6

www.aepd.es

28001 – Madrid

sedeagpd.gob.es

29/63

of the risks throughout the entire data processing cycle, with the primary and ultimate purpose of protecting the rights and freedoms of the data subjects, and not only when the processing actually takes place. This is expressed in the Guidelines 4/2019 of the EDPB regarding Article 25 Data Protection by Design and by Default adopted on October 20, 2020.

In the aforementioned Guidelines, it is stated that:

“35. The ‘moment of determining the means of processing’ refers to the period of time in which the controller is deciding how to carry out the processing and how it will take place, as well as the mechanisms that will be used to carry out such processing. In the process of making such decisions, the data controller must assess the appropriate measures and guarantees to effectively apply the principles and rights of the data subjects in the processing, and take into account elements such as risks, the state of the art, and the cost of implementation, as well as the nature, scope, context, and purposes. This includes the moment of acquiring and implementing the software and hardware and the data processing services.

36. Taking the Data Protection by Design and by Default (PbD) into consideration from the outset is crucial for the correct application of the principles and for the protection of the rights of the data subjects. Furthermore, from a cost-effectiveness perspective, it is also in the interest of the data controllers to take PbD into account as early as possible, as it may later become difficult and costly to introduce changes to already formulated plans and designed processing operations.”

Furthermore, the aforementioned Guidelines 4/2019 of the EDPB provide that “61. To make PbD effective, data controllers must apply the principles of transparency, lawfulness, fairness, purpose limitation, data minimization, accuracy, storage limitation, integrity and confidentiality, and proactive accountability. These principles are enshrined in Article 5 and Recital 39 of the GDPR.”

The Privacy by Design Guide of the AEPD states that “Privacy by Design (hereinafter, PbD) involves using a risk management and proactive accountability approach to establish strategies that incorporate privacy protection throughout the entire lifecycle of the object (whether it is a system, a hardware or software product, a service, or a process). The lifecycle of the object refers to all the stages it goes through, from its conception to its withdrawal, including the phases of development, production deployment, operation, maintenance, and withdrawal.”

The Guide states that “Privacy must be an integral and inseparable part of systems, applications, products, and services, as well as of the business practices and processes of the organization. It is not an additional layer or module that is added to something pre-existing, but must be integrated into the set of non-functional requirements from the very moment it is conceived and designed (...) Privacy is born in the design, before the system is in place.”

C/ Jorge Juan, 6

www.aepd.es

operation and must be guaranteed throughout the entire lifecycle of the data.”

Therefore, the measures referred to in Article 25 of the GDPR aim for the company to integrate the protection of personal data within itself, even before the actual processing of personal data begins. In this way, it is emphasized that the protection of personal data should be considered from the very beginning, from the decision-making or planning stage.

ORANGE, in its written submissions regarding the initiation of the present sanctioning procedure, states that it complies with the provisions of Article 25. To this end, it has indicated that it is the office of the Data Protection Officer (DPO) of the company that intervenes to allow the launch of projects, products, and services that may impact the processing of personal data of ORANGE's customers and users, as reflected in the following documents, which it provides along with its written submissions regarding the initiation of the present sanctioning procedure:

- Document 5 related to the “Privacy Management Dashboard,” which, according to ORANGE, is shared annually with the company.

This document provided by ORANGE is a form in English, referring to the year 2023, in which fields related to the processing of personal data processed in the company must be completed.

- Document 6, which is a report containing the opinion of the audit regarding the application of the principles of privacy by design and by default. It is a report from which conclusions are drawn that do not specify any type of action, but rather from ORANGE it is taken into account “the application of the PbDg Principle in order to proactively anticipate events that may affect privacy, avoiding, as much as possible, their materialization and, therefore, the impact on the rights and freedoms of the affected parties in terms of data protection.”

- Document 7, titled “Data Protection Procedure by Design and by Default.” In this document, it is observed that the application of this principle is intended, but it is not materialized in specific processes; it is only stated that it will be taken into account.

From this documentation, it is concluded that these documents make a generic reference to the possibility of the existence of risks, but they are not identified concretely, and no specific actions are foreseen regarding the possibility of their occurrence. These are not documents from which, after an evaluation of the risks involved in providing a duplicate SIM card to an unauthorized third party, specific procedures are derived from the beginning of the processing that contemplate effective concrete measures for their mitigation.

It should not be forgotten that the GDPR aims to achieve the protection of the rights of the data subjects, and, therefore, the focus must be directed towards the identification and evaluation of the risks to the rights and freedoms of the data subjects, with the subsequent adoption of technical and organizational measures of all kinds aimed at preventing their materialization.

Thus, if the company's approach is not oriented towards the risks to the rights and freedoms of the data subjects, as is the case here, not only will effective protection for the data subjects not be sought, but it also constitutes a breach of Article 25 of the GDPR.

In its submissions regarding the initiation of the present sanctioning procedure, ORANGE states that the action that has motivated the opening of this sanctioning procedure is due to the fraudulent action of an agent who caused an error in the system to allow the execution of a commercial act by misusing their permissions. ORANGE adds that this fraud was considered to be of low risk.

It also highlights that, when explaining this process, “it should not be lost sight of at any time that ORANGE is a telecommunications company that provides services to its customers, and that they demand agility in the completion of the procedures and management they request. Delays in these processes are perceived negatively, which requires that the established protocols be compatible with an adequate user experience and, therefore, to have different options to meet the needs of customers.”

With this statement, the speed of the customer service process is prioritized over the guarantees of individuals' rights.

ORANGE has also stated that the implementation and supervision of technical security measures are

entrusted to the systems department, in the case of fraud detection, although the detection of its possibility is identified by the DPO office or any other area, while the management is coordinated from the specific department of the company specialized in fraud prevention, which evaluates the risks according to a specific protocol and methodology, providing the following documents to substantiate this:

1. Document 8, related to the "Group Risk Management Policy."

This document is provided in English, in which a theoretical reference is made to what is considered a risk.

2. Document 9, which contains the Risk Control and Management Policy.

C/ Jorge Juan, 6

www.aepd.es

28001 – Madrid

sedeagpd.gob.es

32/63

This document is drafted in Spanish and in the introduction it states that it is a model for Risk Control and Management of ORANGE Spain, which is framed within the methodology developed by the ORANGE group. However, the document is written in a theoretical manner, such that there is no specific mention of the possibility that an employee could (...).

3. Document 10 that describes the functioning of the Local Risk Committee

4. Document 11 that enumerates the Internal Control Policy of ORANGE.

From these documents, it is concluded that they refer to the possibility of the existence of risks, but do not specifically identify them, nor do they foresee specific actions regarding the possibility of situations occurring like those that have arisen in the present sanctioning file, in that there is no specific mention of the possibility that an employee could (...).

It should not be forgotten that the GDPR aims to achieve the protection of the rights of the data subjects, and therefore, the focus should be directed towards the identification and evaluation of risks to the rights and freedoms of the data subjects, with the subsequent adoption of all kinds of technical and organizational measures aimed at preventing their materialization.

Thus, if the company's approach is not oriented towards risks to the rights and freedoms of the data subjects, but rather directed towards risks to the company itself, not only will effective protection for the data subjects not be sought, but it also constitutes a breach of Article 25 of the GDPR.

ORANGE has also expressed its disagreement with the fact that human intervention cannot be carried out in the processes. However, at this point, what is being questioned is that ORANGE had not planned any control for cases where it could (...).

Thus, the response given by ORANGE cannot be considered valid since a fully automated process is not being demanded, but rather that in the implementation of the system, the risk was not foreseen, as no mechanism was established to prevent the incorrect use of its manual protocols.

All of this, considering that the usual procedure for issuing duplicate SIM cards from ORANGE is automated, and it has stated in this same written submission that it has suspended the possibility of manual validation of the identity documents of the SIM card applicants.

Furthermore, as has been pointed out earlier, it should also not be forgotten that ORANGE has stated, when explaining this process, that "it must not be lost sight of at any time that ORANGE is a telecommunications company that provides services to its customers, and that these demand..."

C/ Jorge Juan, 6

www.aepd.es

28001 – Madrid

sedeagpd.gob.es

33/63

agility in the execution of the procedures and actions requested. The delay in these actions is perceived negatively, which necessitates that the established protocols be compatible with an adequate user experience and, therefore, to have different options to meet the needs of the clients."

For all the above reasons, this allegation by ORANGE cannot be taken into account, insofar as it is not

a matter of being unable to automate the procedures, but rather that the agility in the actions does not justify nor can it be an impediment to comply with what is provided in the data protection regulations, which are mandatory in those cases, such as the present, where personal data of the interested parties is being processed.

In this regard, the process for issuing duplicates of SIM cards involves controls and security measures aimed at ensuring that the SIMs are issued at the request of the clients and once their identity has been verified, taking into account the protection of the privacy of the interested parties, and believes that this Agency is attempting to disqualify the documentary evidence solely on the premise that a specific crime has occurred.

It adds that ORANGE does have policies aimed at ensuring the application of data protection principles in its business processes, regardless of whether a specific reference to privacy guarantees is identified in each of them, since, although they address the associated risks in this area, it is not the only one taken into account, just as the analyzed criminal risks, economic risks, or reputational risks are not specified in each of them.

In this sense, as already stated in the proposed resolution, the principle of data protection by design imposes that, from the earliest stages of planning a processing operation, this principle must be considered: the data controller, from the moment a potential processing of personal data is designed and planned, must determine all the elements that make up the processing, for the purpose of effectively applying the principles of data protection, integrating the necessary guarantees in the processing with the ultimate aim of, in compliance with the provisions of the GDPR, protecting the rights of the interested parties.

Therefore, from the design of the processing, there were no measures from Article 25 of the GDPR (...). The absence of measures to ensure that the request for a duplicate card was made by the line holder, coupled with the fact that it was not verified that the delivery was made to the holder, constitutes a breach of the principle of data protection by design.

This implies that ORANGE would not have adequately identified and analyzed the risks that (...), nor anticipated or applied from the design the appropriate technical and organizational measures, to effectively apply the data protection principles required by Article 25 of the GDPR.

C/ Jorge Juan, 6

www.aepd.es

28001 – Madrid

sedeagpd.gob.es

34/63

ORANGE merely states that it complied with the required provisions, and provides documentation in which it claims to take this article into account, but none of them specifically indicates that the principle of data protection by design had been implemented and by (...).

To address this issue, it states that the initial documentation it has already provided is the initial information provided for any project in which personal data is processed in order to begin regulating the various activities from a perspective that safeguards privacy and the protection of personal data, and that, for each particular case, the measures deemed appropriate are applied, such as training for personnel responsible for the processes. However, it still fails to present such documentation. It states that it submitted document No. 12, in the allegations to the initiation agreement, which together with document 1 presented in the written allegations to the proposed resolution, would prove that the risk had indeed been identified.

However, this Agency understands that these documents do not demonstrate compliance with the principle of data protection by design. The aforementioned document No. 12 to which it refers is dated 2023 and is titled (...).

In the document referred to as 1 of the allegations to the proposed resolution, a risk matrix is provided in which the risk "Fraudulent use of data-3rd parties" is identified, without further development, and is assessed as a low risk but it is not indicated whether the risk is to the rights and freedoms of the interested parties or to the continuity of the business.

ORANGE provides as document 2 of its allegations to the proposal the minutes of the Local Risk

Committee from 2022 in which the OSP risk management policy and the OSP risk matrix are approved, among other issues, but from its content it seems to imply that they evaluate the risk to the continuity of the business.

It also provides document No. 3, the map of residual risks from the perspective of the rights and freedoms of the interested parties referred to the year 2022 where the risk of fraud was identified as low, and which according to ORANGE was addressed in the Local Risk Committee of 2022 whose minutes were attached as document No. 2.

In this regard, the aforementioned minutes of the Local Risk Committee, dated 3/10/2022, include in section 6. Risks: Integration of Risk Maps: “(…).”

In turn, in section 8 of the minutes: Telco Fraud is recorded: “(…).”

C/ Jorge Juan, 6

www.aepd.es

28001 – Madrid

sedeagpd.gob.es

35/63

In section 9 regarding Non-Telco Fraud, it is added:

“(…).”

As for the risk map provided as document No. 3, titled 2022 Non-Telco Fraud risk map: Fraudulent use of Data-3rd parties, it contains “(…).”

And it includes the following:

“(…).”

Well, according to ORANGE's allegations, this document would have been presented to the Committee whose minutes have been provided as document No. 2, and it would have been discussed therein; however, there is no reference to it in the aforementioned committee minutes.

Furthermore, it must be taken into account that, despite ORANGE's statements, this Agency maintains that the risks to the rights and freedoms derived from (...). The internal risk that employees may commit some type of infringement has not been considered, but it is also understood that the impact cannot be classified as limited based on the fact that banking entities must refund any charge made due to the violation of their systems.

This is evident in the case where the claimant has suffered economic losses amounting to 9,000 euros, not to mention that in the complaint before the Court that ORANGE has presented in its written allegations to the initiation agreement, there are more individuals who could have been affected, even if they have not filed a complaint with the AEPD.

Thus, the impact that this risk has on the rights and freedoms of individuals is high; therefore, the residual risk cannot be classified as low without the implementation of appropriate measures.

For all these reasons, this Agency has considered that, despite having presented a document dated 2022, it is understood that this does not determine compliance with Article 25 of the GDPR.

ORANGE, in its appeal, “urges this Agency to enumerate what measures are appropriate for this type of circumstance in which an employee of a data processor (a distributor), in their judgment and based on a risk analysis, considers it appropriate to issue a duplicate SIM card committing a crime, even knowing that there is traceability to determine who carries out such action.” This Agency wishes to express that it is ORANGE who knows its organization, and it is they who must take into account the measures to be implemented, and no pronouncement will be made in this regard.

Additionally, it provides two expert reports in which, from the perspective of security and process analytics, it seeks to demonstrate that ORANGE applies, both at the time of determining the means and at the time of the processing itself, that it does have appropriate technical and organizational measures in line with the identified risks, designed to comply with the requirements of Article 25 of the GDPR and protect the rights of the data subjects.

Despite ORANGE's statements, these new documents submitted in the appeal phase further evidence what has already been noted in the resolution now being appealed, which is that the risks that a case like the one at hand could pose to individuals had not been analyzed.

These reports are prepared with the organization that commissioned them in mind and do not take into account the risks that may arise concerning the rights and freedoms of individuals.

For this reason, this allegation is dismissed.

6.- ON THE EXISTENCE OF A CONCURSO DE INFRACCIONES (CUMULATIVE OFFENSES).

This allegation has already been addressed in the resolution now being appealed in the following manner:

“ORANGE understands that the initiation agreement refers to a single fact, subject and basis, which would be the adoption of measures in the procedure for duplicating the SIM card in the specified cases of manual intervention, which would constitute a case of cumulative offenses in criminal law or a concurrence of offenses or violations in administrative law, which applies ‘as long as the application of one provision prevents or subsumes the applicability of the other,’ and which makes it contrary to the legal system to sanction the offender twice for the same offense.

ORANGE understands that, from the initiation agreement, it can be inferred that, in relation to the analyzed facts, there is a direct connection between the violations of the two articles.

In this way, the infringement of Article 6.1 GDPR, or the existence of an alleged unlawful data processing, was necessary and inevitable for a violation of the principle of privacy by design and by default to occur, resulting from the lack of sufficient security measures. Thus, if ORANGE had had measures that would have prevented the duplication of the SIM card, the infringement of the principle of privacy by design and by default of Article 25 of the GDPR could not have been concluded.

Consequently, a cumulative offense would be established, as the commission of one would necessarily imply the commission of the other.

However, regarding this issue, it must be taken into account that Articles 6.1 and 25 are classified differently in the GDPR, are qualified differently for the purposes of prescription under the LOPDGDD, and each enjoys its own entity.

If ORANGE's assertion were true, the violations of these articles would not be classified as different violations.

C/ Jorge Juan, 6

www.aepd.es

28001 – Madrid

sedeagpd.gob.es

37/63

Thus, Article 6.1 of the GDPR establishes the circumstances that allow for the lawful processing of personal data.

In the present case, ORANGE was accused of issuing a SIM card in the name of the claimant, without the claimant having requested it, and delivering it to an unauthorized third party.

ORANGE has acknowledged this, both in its written statement dated January 30, 2023, and in its written statement dated March 30, 2023, asserting that this duplicate was issued on November 15, 2022, without it being requested by the claimant.

Therefore, ORANGE issued a SIM card to a third party who was not the holder of the line, and did not follow the procedure implemented by itself, since the duplicate of the card was issued without it being requested by (...) of the line. In short, it carried out these operations of personal data processing without any of the bases for legitimacy provided for in Article 6 of the GDPR being present.

Consequently, the diligence employed by ORANGE in identifying the person requesting the duplicate has been called into question.

In this regard, Recital 40 of the GDPR states:

“(40) For processing to be lawful, personal data must be processed with the consent of the data subject or on another legitimate basis established in accordance with law, whether in this Regulation or by virtue of another Union or Member State law to which this Regulation relates, including the necessity of complying with a legal obligation applicable to the data controller or the necessity of performing a contract to which the data subject is party or for the purpose of taking steps at the request of the data subject prior to entering into a contract.”

On the other hand, in general terms, ORANGE processes its customers' data under the provisions of Article 6.1.b) of the GDPR, when it is considered necessary for the performance of a contract to which the data subject is party or for the application at the request of the data subject of pre-contractual measures.

For other cases, the lawfulness of processing is based on the grounds provided for in Article 6.1.a), c), e), and f) of the GDPR.

As previously noted, the processing carried out by ORANGE in this case cannot be based on the provisions of paragraph b of Article 6.1, since this duplicate SIM card was not based on the performance of any contract, as it was not necessary for its execution nor had it been requested by the claimant; nor was the processing based on any other grounds provided for in Article 6.

On the other hand, Article 25 of the GDPR states:

C/ Jorge Juan, 6
www.aepd.es
28001 – Madrid
sedeagpd.gob.es

38/63

“1. Taking into account the state of the art, the cost of implementation, and the nature, scope, context, and purposes of the processing, as well as the risks of varying probability and severity that the processing poses to the rights and freedoms of natural persons, the data controller shall implement, both at the time of determining the means of processing and at the time of the processing itself, appropriate technical and organizational measures, such as pseudonymization, designed to effectively apply the principles of data protection, such as data minimization, and to integrate the necessary safeguards into the processing, in order to comply with the requirements of this Regulation and protect the rights of data subjects.

2. The data controller shall implement appropriate technical and organizational measures to ensure that, by default, only personal data that are necessary for each specific purpose of the processing are processed. This obligation shall apply to the amount of personal data collected, the extent of their processing, the duration of their storage, and their accessibility. Such measures shall ensure in particular that, by default, personal data are not accessible, without the intervention of the data subject, to an indeterminate number of natural persons.

3. An approved certification mechanism under Article 42 may be used as an element that demonstrates compliance with the obligations laid down in paragraphs 1 and 2 of this Article.”

As can be seen, this article starts from the need to take into account a series of elements:

- State of the art
- Cost of implementation
- Nature, scope, context, and purposes of the processing
- Risks posed by the processing to the rights and freedoms of natural persons.

Furthermore, it imposes an obligation on the controller, who determines the purposes and means of processing, giving special relevance to the means.

And it must apply, both when determining the means of processing and at the time of the processing itself, appropriate technical and organizational measures designed to effectively apply the principles of data protection and integrate the necessary safeguards into the processing.

With this, a dual purpose is pursued:

- To comply with the requirements of the GDPR
- To protect the rights of data subjects.

At this point, it is also necessary to take into account the provisions of Recital 78 of the GDPR previously reproduced.

C/ Jorge Juan, 6
www.aepd.es
28001 – Madrid
sedeagpd.gob.es

39/63

Thus, the measures provided for in Article 25 of the GDPR are not exclusively security measures; rather, they aim for the company or organization to integrate the protection of personal data by design within its structure, organization, and ordinary functioning. That is to say, it should be an integral and relevant part of the organization, even before the actual processing of personal data begins, from the

decision-making or planning stage.

The obligation affects the entire organization and involves a continuous process of review and feedback to verify whether all existing technical and organizational measures, of all types and implemented by the organization, are adequate to meet the requirements of the GDPR and protect the rights of the data subjects. In this way, if they are found to be inadequate, they may be modified or, if necessary, reinforced by incorporating new measures that ensure a more appropriate protection of personal data.

Therefore, in accordance with all of this, it can be seen that the perspective or angle through which reality is viewed is different from that provided for in Article 6 of the GDPR.

In this sense, the GDPR articulates a complete system aimed at ensuring the protection of citizens' personal data, and for this purpose, it focuses its attention on various aspects that must be examined by the data controllers or processors.

Each article constitutes an angle from which to observe reality in order to articulate the measures that guarantee adequate protection of personal data, which must be taken into account to ensure protection in accordance with the provisions of the GDPR.

In its written allegations regarding the initiation agreement, ORANGE states that "the infringement of Article 6.1 GDPR, or the existence of an alleged unlawful data processing, was necessary and inevitable for a violation of the principle of privacy by design and by default to occur, derived from the lack of sufficient security measures. Thus, if ORANGE had had measures that allowed for the prevention of SIM card duplication, the infringement of the principle of privacy by design and by default of Article 25 of the GDPR could not have been concluded."

However, this statement cannot be accepted, as it has been indicated that these are infringements that require the concurrence of different elements for their commission. Thus, on one hand, it is necessary for the commission of the infringement of Article 6 of the GDPR that personal data processing is carried out without having diligently verified that a legal basis for it exists. On the other hand, the infringement of Article 25 requires the lack or deficient implementation from the design of appropriate measures to comply with the GDPR, which can occur regardless of whether data processing takes place without a legal basis. Obviously, both infringements must involve a lack of diligence, but regarding different behaviors.

ORANGE cites the Judgment of the National Court of April 24, 2013, Rec. 69/2011, according to which:

"To assess this infringement, it is essential, in the opinion of the Chamber, to refer to the concurrence of infringements whose existence is also invoked in the complaint. For this purpose, it must be brought to attention what is provided in Article 4.4 of Royal Decree 1398/1993, according to which: in the absence of specific regulation established in the corresponding norm, when the commission of one infringement necessarily derives from the commission of another or others, only the sanction corresponding to the most serious infringement committed shall be imposed.

This provision has been interpreted by the Supreme Court ruling of February 8, 1999 (Rec. 9/1996) in the sense that the application of the medial concurrence requires a necessary derivation of some infringements concerning others and vice versa, so it is essential that one cannot be committed without executing the others."

ORANGE understands that, in the event of an infringement of Articles 6.1 and 25 of the GDPR being recognized, these would be concurrent infringements, and that the applicable sanction would in any case correspond to the breach of Article 6.1 GDPR, taking into account the provisions of Article 29.5 of Law 40/2015, of October 1, on the Legal Regime of the Public Sector, according to which:

"when the commission of one infringement necessarily derives from the commission of another or others, only the sanction corresponding to the most serious infringement committed shall be imposed." However, it must be taken into account, in addition to what has been previously stated by this Agency, that, first of all, Article 29 of the LRJSP does not apply to the sanctioning regime imposed by the GDPR.

1. The GDPR is a complete system.

The GDPR is a community regulation directly applicable in the Member States, which contains a new, closed, complete, and global system aimed at ensuring the protection of personal data uniformly

throughout the European Union.

In relation, specifically and also, to the sanctioning regime provided for therein, its provisions apply immediately, directly, and integrally, foreseeing a complete and gapless system that must be understood, interpreted, and integrated absolutely, completely, and integrally, thus leaving its ultimate purpose intact, which is the effective and real guarantee of the fundamental right to the Protection of Personal Data.

41/63

on the contrary, it determines the reduction of guarantees of the rights and freedoms of citizens.

In fact, a specific example of the non-existence of gaps in the GDPR system is Article 83 of the GDPR, which determines the circumstances that may operate as aggravating or mitigating factors regarding an infringement (Art. 83.2 of the GDPR) or specifies the existing rule concerning a possible mitigating circumstance (Art. 83.3 of the GDPR).

In addition to the above, we must add that the GDPR does not allow the development or specification of its provisions by the legislators of the Member States, except for what the European legislator has specifically provided, delimiting it very concretely (for example, the provision of Art. 83.7 of the GDPR). The LOPDGDD only develops or specifies some aspects of the GDPR to the extent that it allows and with the scope that it permits.

This is so because the purpose intended by the European legislator is to establish a uniform system throughout the European Union that guarantees the rights and freedoms of individuals, corrects behaviors contrary to the GDPR, promotes compliance, and enables the free movement of these data. In this regard, Recital 2 of the GDPR states that,

“(2) The principles and rules concerning the protection of natural persons with regard to the processing of their personal data must, regardless of their nationality or residence, respect their fundamental freedoms and rights, in particular the right to the protection of personal data. This Regulation aims to contribute to the full realization of an area of freedom, security, and justice and of an economic union, to economic and social progress, to the strengthening and convergence of economies within the internal market, as well as to the well-being of natural persons.” (the emphasis is ours)

Recital 13 of the GDPR further indicates that,

“(13) To ensure a consistent level of protection of natural persons throughout the Union and to avoid divergences that hinder the free movement of personal data within the internal market, a regulation is necessary that provides legal certainty and transparency to economic operators, including microenterprises and small and medium-sized enterprises, and offers natural persons in all Member States the same level of enforceable rights and obligations and responsibilities for controllers and processors, in order to ensure consistent supervision of personal data processing and equivalent sanctions in all Member States, as well as effective cooperation between the supervisory authorities of the different Member States. The proper functioning of the internal market requires that the free movement of personal data in the Union is not restricted or prohibited for reasons related to the protection of natural persons with regard to the processing of personal data.” (the emphasis is ours)

In this system, what is decisive in the GDPR is not the fines. The corrective powers of the supervisory authorities provided for in Art. 58.2 of the GDPR, combined with the provisions of Art. 83 of the GDPR, show the prevalence of corrective measures over fines.

Thus, Art. 83.2 of the GDPR states that “Administrative fines shall be imposed, depending on the circumstances of each individual case, as an additional or substitute measure for those provided for in Article 58, paragraph 2, letters a) to h) and j).”

In this way, the corrective measures, which are all those provided for in Art. 58.2 of the GDPR except for the fine, take precedence in this system, relegating the economic fine to cases where the circumstances of the specific case determine that a fine is imposed along with the corrective measures or in substitution of them.

And all this with the aim of enforcing compliance with the GDPR, preventing non-compliance, promoting compliance, and ensuring that the infringement is not more profitable than non-compliance. Therefore, Art. 83.1 of the GDPR warns that “Each supervisory authority shall ensure that the imposition of administrative fines under this Article for the infringements of this Regulation referred to in paragraphs 4, 5, and 6 is, in each individual case, effective, proportionate, and dissuasive.”

Fines must be effective, proportionate, and dissuasive for the achievement of the purpose intended by the GDPR.

For this system to function with all its guarantees, it is necessary that several elements are deployed in an integral and complete manner. The application of rules external to the GDPR regarding the determination of fines in each of the Member States applying their national law, whether due to aggravating or mitigating circumstances not provided for in the GDPR - or in the LOPDGDD in the Spanish case - or due to the application of a mitigating circumstance different from that provided in the GDPR, would undermine the effectiveness of the system, losing its meaning, its teleological purpose, resulting in fines imposed for different infringements ceasing to be effective, proportionate, and dissuasive. And in this way, it would also deprive the interested parties of the effective guarantee of their rights and freedoms, weakening the uniform application of the GDPR. The mechanisms for protecting the rights and freedoms of citizens would be diminished and it would be contrary to the spirit of the GDPR.

The GDPR is endowed with its own principle of proportionality that must be applied in its strict terms.

2. There is no legal gap, there is no supplementary application of Art. 29 of the GDPR.

C/ Jorge Juan, 6

www.aepd.es

28001 – Madrid

sedeagpd.gob.es

43/63

In addition to the above, it should be noted that there is no legal gap regarding the application of medial concurrence. Neither the GDPR allows nor the LOPDGDD provides for the supplementary application of the provisions of Article 29 of the LRJSP.

In Title VIII of the LOPDGDD relating to "Procedures in case of possible violation of data protection regulations," Article 63, which opens the Title, states that "The procedures processed by the Spanish Data Protection Agency shall be governed by the provisions of Regulation (EU) 2016/679, by this organic law, by the regulatory provisions issued in its development, and, insofar as they do not contradict them, subsidiarily by the general rules on administrative procedures." While there is a clear reference to the LPACAP, there is absolutely no provision for subsidiary application regarding the LRJSP, which does not contain any provision in its articles relating to any administrative procedure. Just as the AEPD is not applying the aggravating and mitigating factors provided in Article 29 of the LRJSP, since the GDPR establishes its own, therefore, there is no legal gap or subsidiary application of the same, nor is there room for the application of the section relating to medial concurrence for the same reasons.

In the specific case examined, and without prejudice to the above, it should be emphasized that there is no medial concurrence.

Article 29.5 of the LRJSP states that "When the commission of an infringement necessarily results in the commission of another or others, only the sanction corresponding to the most serious infringement committed shall be imposed."

Well, medial concurrence occurs when, in a specific case, the commission of one infringement is a necessary means to commit another distinct one. The established facts determine, as stated, the commission of two distinct infringements, without the violation of Article 6 of the GDPR (lack of legitimacy in the issuance of the duplicate SIM card of the complaining party), as asserted by ORANGE, being the necessary means by which the infringement of Article 25 of the GDPR occurs. Finally, ORANGE refers to the Guidelines 4/2022 on the calculation of administrative fines under the GDPR, which stipulate the criteria that the administrative authority must follow to evaluate, prior to the imposition of the sanction, the possible concurrence of these.

Regarding the citation of the Guidelines 04/2022 of the EDPB on the calculation of administrative fines in accordance with the GDPR, in its version 2.1, adopted on May 24, 2023, in its section 22, reference is made to three types of concurrence, namely, of infringement, unit of action, and plurality of actions:

C/ Jorge Juan, 6

www.aepd.es

28001 – Madrid

“When examining the analysis of the traditions of the Member States regarding rules of concurrence, as indicated in the jurisprudence of the CJEU, and taking into account the different areas of application and the legal consequences, these principles can be grouped approximately into the following three categories: - Concurrence of infringements (chapter 3.1.1), - Unit of action (chapter 3.1.2), - Plurality of actions (chapter 3.2).

In cases of concurrence of infringements, the provision established in Article 83.3 of the GDPR applies, which establishes a quantitative limit in these cases of concurrence:

“If a controller or a processor intentionally or negligently infringes various provisions of this Regulation for the same processing operations or related operations, the total amount of the administrative fine shall not exceed the amount provided for the most serious infringements.” (the underlining is ours).

If we were to accept the argument put forward by ORANGE, it could be inferred that the “full applicability of medial concurrence” referred to the preferential application of Article 29 of the LRJSP, in its sole intention to pay a single fine instead of the two imposed, displaces or nullifies the validity of Article 83.3 of the GDPR, which is contrary to the legal system.

Finally, and no less importantly, the AEPD does not sanction for the same offense, as ORANGE claims, but rather, through proven facts, the commission of two differentiated infringements has been established, classified in a differentiated manner, and there is, moreover, no medial concurrence in the specific case.

Lastly, it is not true that the non-compliance with Article 25 of the GDPR requires data processing without a basis of legitimacy. Article 25 imposes an obligation on the controller to adopt the necessary measures to comply with the principle of data protection by design, without it being necessary for the lack of measures or their poor implementation to result in any other outcome contrary to the GDPR. It is the non-compliance with the provisions of Article 25 that is sanctioned, which can occur regardless of whether data processing without a basis of legitimacy takes place, and therefore this allegation should be rejected.”

For all the above reasons, this allegation is dismissed.

7.- ON THE INADMISSIBILITY OF OBJECTIVE LIABILITY.

This allegation has already been addressed in the resolution now being appealed in the following manner:

“In relation to this issue, ORANGE points out that the initiation agreement of this sanctioning procedure is based on a result analysis, insofar as it would consider that the issuance of the duplicate SIM card automatically entails the consideration that no measures were taken.

C/ Jorge Juan, 6

www.aepd.es

28001 – Madrid

sedeagpd.gob.es

adequate, thereby automatically arising the direct responsibility on the part of ORANGE, establishing an obligation of result.

ORANGE adds that this AEPD limits the obligation to the result, indicating that the failure of ORANGE's agents to meet the measures automatically implies that the measures were insufficient, and that this fact entails the adoption of a principle of objective liability which has been prohibited by our legal system on numerous occasions by the Constitutional Court.

In contrast, this Agency considers that the deficiencies observed in the measures from the design adopted by ORANGE have been made evident, demonstrating non-compliance with Article 25 of the GDPR.

In the present procedure, the existing risk arising from the application known as PSD2 is being analyzed, which is when the type of fraud detailed in this sanctioning file begins to occur, through the use of a duplicate SIM card obtained improperly by a person other than its holder.

Thus, the infringement arose not only from the lack of measures for the issuance of duplicate SIM

cards but also from the need for their review and reinforcement. This is determined in Article 25 of the GDPR when it states: "...the data controller shall apply, both at the time of determining the means of processing and at the time of the processing itself, appropriate technical and organizational measures..."

It is not enough to implement technical and organizational measures; they must be adapted and reviewed to mitigate risks. The continuous advancement of technology and the evolution of processing lead to the continuous emergence of new risks that must be managed, as is the case with the SIM swapping attack, which has long been used by cybercriminals to carry out computer fraud. This is not an operation unknown to ORANGE that could have surprised it; therefore, when assessing the risks, it should have taken this into account, which translates into a greater use by criminals of mechanisms to seize the duplicate SIM cards of customers, which cannot be ignored by ORANGE. In this context, the GDPR requires that data controllers review the measures from the design stage, establishing appropriate ones to demonstrate that the rights and freedoms of individuals are guaranteed, taking into account, among others, the "risks of varying probability and severity for the rights and freedoms of natural persons" (Article 24.1) by applying the appropriate measures.

In the present case, the technical and organizational measures implemented from the design have proven ineffective, as has been confirmed in this sanctioning procedure.

The technical and organizational measures must guarantee a level of protection appropriate to the risk, which has not been done in this case.

C/ Jorge Juan, 6
www.aepd.es
28001 – Madrid
sedeagpd.gob.es
46/63

To select the appropriate measures, the responsible party must base their decisions on the risks to individuals, as well as what is reasonable and technically possible. Article 28.2.a) of the LOPDGDD establishes certain scenarios in which it is necessary to address greater risks than those the responsible party might estimate if they only considered their own interests (identity theft, economic harm, etc.).

As previously noted in this sanctioning procedure, the SIM card constitutes the physical medium through which access to the personal data of the affected individual is obtained. If its availability and control are not guaranteed, access to the personal data of the holder, as well as the potential use by third parties, becomes a threat that can have devastating effects on the lives of these individuals.

The Constitutional Court stated in its Judgment 94/1998, of May 4, that we are dealing with a fundamental right to data protection, which guarantees individuals control over their data, any personal data, and its use and destination, to prevent the illicit trafficking of such data or harm to the dignity and rights of the affected parties; thus, the right to data protection is configured as a citizen's ability to oppose the use of certain personal data for purposes other than those that justified its acquisition.

The risk-based approach and the flexible model to the risk imposed by the GDPR—starting from the dual configuration of security as a principle related to processing and an obligation for the responsible party or the processor—does not impose infallibility of the measures in any case, but rather their constant adequacy to a risk that, as in the examined case, is real, probable, and not negligible, high, and with a very significant impact on the rights and freedoms of citizens.

In the instruction of the procedure, it has been established that technical and organizational measures had not been adapted from the design to the risks posed by technological evolution, which puts the rights of the interested parties at serious risk, as the measures were not effective in preventing or mitigating the greater risk of fraud that could arise in the request for duplicates of SIM cards, with the aim of perpetrating a SIM swapping attack.

Furthermore, ORANGE cannot deny the fact that it processes personal data on a large scale. Thus, in sanctioning matters, the principle of culpability applies (STC 15/1999, of July 4; 76/1990, of April 26; and 246/1991, of December 19), which means that some form of intent or fault must be present. As stated in the STS of January 23, 1998, "...there can be said to be a decisive line of jurisprudence that rejects objective liability in the sanctioning sphere of the Administration, requiring the presence of

intent or fault, in line with the interpretation of STC 76/1990, of April 26, by indicating that the principle of culpability can be inferred from the principles of legality and prohibition of excess (Article 25 of the Constitution) or from the inherent requirements of the Rule of Law."

C/ Jorge Juan, 6
www.aepd.es
28001 – Madrid
sedeagpd.gob.es
47/63

The lack of diligence in implementing the appropriate measures to verify that the person requesting or activating a duplicate SIM card is the rightful owner is, precisely, what constitutes the element of culpability.

Regarding ORANGE being a victim of fraud, it should be noted that ORANGE must be in a position to establish mechanisms that prevent the fraudulent duplication of SIM cards, measures that respect the integrity and confidentiality of data and that prevent a third party from accessing data that does not belong to them, as it is the operator's responsibility to process personal data in accordance with the GDPR (recitals 76, 77, 78, 79, 81, and 83 of the GDPR; Article 32 of the GDPR and Article 28 of the LOPDGDD).

Periodic testing, measurement, and evaluation of the effectiveness of the technical and organizational measures applied to processing are the responsibility of each data controller and processor in accordance with the GDPR.

Therefore, ORANGE, as the data controller, is obliged to verify both the selection and the level of effectiveness of the technical and organizational means used. The thoroughness of this verification must be assessed through the lens of adequacy to risks and proportionality in relation to the state of technical knowledge, implementation costs, and the nature, scope, context, and purposes of the processing.

Certainly, the principle of accountability provided for in Article 28 of the LRJSP states: "Only individuals and legal entities may be sanctioned for acts constituting administrative infractions, as well as, when a law recognizes their capacity to act, groups of affected parties, unions, and entities without legal personality and independent or autonomous assets, that are found responsible for them due to intent or negligence."

However, the manner of attributing responsibility to legal entities does not correspond to the forms of culpability that are attributable to human conduct. Thus, in the case of infractions committed by legal entities, although the element of culpability must be present, it necessarily applies differently than it does with individuals.

According to STC 246/1991 "(...) this distinct construction of the attribution of authorship of the infraction to the legal entity arises from the very nature of the legal fiction to which these subjects respond. They lack the volitional element in the strict sense, but not the capacity to infringe the norms to which they are subject.

The capacity for infringement and, therefore, direct reproachability that derives from the legal good protected by the norm that is infringed and the necessity for such protection to be truly effective, and the risk that, consequently, must be assumed by the legal entity that is subject to compliance with that norm" (in this sense, STS of November 24, 2011, Rec 258/2009).

C/ Jorge Juan, 6
www.aepd.es
28001 – Madrid
sedeagpd.gob.es
48/63

To the above, it should be added, following the judgment of January 23, 1998, partially transcribed in the Supreme Court judgments of October 9, 2009, Rec 5285/2005, and October 23, 2010, Rec 1067/2006, that "although the culpability of the conduct must also be subject to proof, it should be considered in terms of the assumption of the corresponding burden, that ordinarily the volitional and cognitive elements necessary to appreciate it are part of the proven typical conduct, and that their exclusion requires evidence of the absence of such elements, or in its normative aspect, that due

diligence has been exercised by the party claiming their non-existence; it is not enough, in summary, for exculpation against a typically unlawful behavior to invoke the absence of fault."

The ultimate responsibility for the processing remains attributed to the data controller, who determines the existence of the processing and its purpose. Let us remember that operators process the data of their customers by determining purposes and means. Therefore, it is the responsibility of the operators (ORANGE, in this case) to implement appropriate measures that ensure compliance with the GDPR, so that if such a principle is compromised due to a lack of diligence in implementing sufficient measures for it, the responsibility for such an infringement will be attributed to the operator in question. In this regard, the Judgment of the National Court of February 9, 2023 states:

"The principle of culpability derived from Article 25 of the Spanish Constitution, as indicated by the Constitutional Court Judgment 246/1991, of December 19, constitutes a basic structural principle of sanctioning administrative law, and is recognized in Article 28.1 of Law 40/2015, of October 1, on the Legal Regime of the Public Sector, which provides that: 'Only individuals or legal entities that are found responsible for acts constituting administrative infringement may be sanctioned for such acts, either by intent or negligence.'"

Therefore, as noted in the Supreme Court Judgment of March 18, 2005, Rec. 7707/2000, it is evident, "that an administrative infringement could not be deemed committed if the subjective element of culpability did not concur, or in other words, if the conduct typically constitutive of an administrative infringement were not attributable to intent or negligence."

Regarding the fact that the risks concerning the duplication of SIM cards had not been identified prior to the application of the PSD2 Directive, it should be noted that the appealed resolution already indicates - page 872 - "In the present procedure, the existing risk before the application of the so-called PSD2 is not being analyzed, but rather the risk that arises from its application, which is when fraud begins to be used through the use of a duplicate of a SIM card improperly obtained by a person other than its holder (...) in the present case, the security measures implemented are not sufficient to guarantee the confidentiality of the personal data in question."

C/ Jorge Juan, 6

www.aepd.es

28001 – Madrid

sedeagpd.gob.es

49/63

Now, furthermore, it is clear that the risk of identity theft is permanently present in the business activity of (...). It is a real risk aimed at impersonating another person and seeks, in cases such as the one examined, the contracting of products or the obtaining of a duplicate SIM card by someone who is not the actual holder of it, a risk that the appellant cannot claim was unknown to them.

Regarding the alleged objective liability, the contested resolution does not hold (...) responsible for the outcome, but rather for a loss of confidentiality linked to the insufficiency of the security measures implemented and, ultimately, due to a lack of diligence on the part of that entity.

(...)

This lack of diligence on the part of (...), as the data controller, when implementing appropriate security measures at the outset to verify that the person requesting or activating the duplicate SIM card is the holder of it constitutes the element of culpability.

Consequently, the subjective element of culpability necessary to impose a sanction is present, which is incompatible with the existence of the alleged invincible error. The security measures implemented subsequently do not affect the commission of the infringement and, contrary to what the claimant intends, cannot justify the application of an exemption, without prejudice to the fact that they have been taken into consideration as a mitigating factor under Article 83.2.c) of the GDPR when determining the sanction.

This Agency wishes to express that, contrary to the allegations of ORANGE, which insists that this Agency expects ORANGE to foresee each and every threat that may occur, anticipating a result in which the measures are infallible, overlooking threats that are difficult to foresee, as would be the case here, Article 25 of the GDPR states: "...the data controller shall implement, both at the time of determining the means of processing and at the time of the processing itself, appropriate technical and

organizational measures...”

The Guidelines 4/2019 of the European Data Protection Board (EDPB) regarding Article 25 Data protection by design and by default, Version 2.0, Adopted on October 20, 2020, indicate:

“29 The GDPR adopts a coherent risk-based approach in many of its provisions, in Articles 24, 25, 32, and 35, in order to determine the appropriate technical and organizational measures to protect individuals and their personal data and to comply with the requirements of the GDPR. The protected goods are always the same (individuals, through the protection of their personal data), against the same risks (to the rights of individuals), and taking into account the same circumstances (the nature, scope, context, and purposes of the processing).

C/ Jorge Juan, 6

www.aepd.es

28001 – Madrid

sedeagpd.gob.es

50/63

30. In conducting the risk analysis for compliance with Article 25, the data controller must determine the risks posed by a violation of the principles concerning the rights of data subjects, as well as their likelihood and severity, in order to apply measures that effectively mitigate the identified risks. In risk assessments, it is crucial to carry out a systematic and thorough evaluation of the processing. For example, a controller evaluates the specific risks associated with the absence of freely given consent, which constitutes a violation of the principle of lawfulness, in the course of processing personal data of children and young people under 18 years of age as a vulnerable group, in a case where there is no other legal basis, and applies appropriate measures to address and effectively mitigate the identified risks associated with this group of data subjects” (the underlining is ours).

In summary, compliance with the principle of data protection by design requires identifying the specific risks to the rights and freedoms of individuals posed by the processing, analyzing and evaluating them in such a way as to allow for the effective determination and application from the outset of the processing of specific technical and organizational measures to guarantee each of the principles of data protection, such as lawfulness, accuracy, and confidentiality, which in this case has not been done.

As already noted in the response to the allegations regarding the initiation agreement, it is understood that ORANGE, when assessing the risks of using the application it has implemented to issue duplicate SIM cards, did not take into account the risks, as well as their impact on the rights and freedoms of individuals. It has already been demonstrated that the impact this potential risk had on the rights and freedoms of individuals is high, and this was also not taken into account. The lack of diligence in implementing appropriate measures from the outset to verify (...), precisely, constitutes the element of culpability.

Therefore, it is appropriate to dismiss the allegation presented by ORANGE.

8.- ON THE MEASURES ADOPTED AND IMPLEMENTED BY ORANGE.

ORANGE reiterates that the measures presented throughout the sanctioning procedure had not been taken into account by this Agency, and therefore, it lists them again. However, this Agency wishes to state that they have been analyzed and assessed, and for this reason, what was previously responded to is reproduced, both in the allegations to the initiation agreement and in the allegations to the proposed resolution.

“ORANGE points out that it has already enumerated the measures it has deployed, both beforehand and subsequently, so that this Agency can appreciate the constant evolution and risk analysis, as well as the measures applied, taking into account the evolution of the cases of SIM Swapping fraud.

C/ Jorge Juan, 6

www.aepd.es

28001 – Madrid

sedeagpd.gob.es

51/63

ORANGE insists that it had established the following measures:

1. Measures implemented by ORANGE to prevent the commission of fraud resulting from the identity theft of its customers.

- Documentation already provided that is made available to agents and other personnel capable of carrying out actions at ORANGE.

- Additional communications reiterating the action protocols for issuing duplicate SIM cards.

(...).

- ORANGE is part of the Spanish Association for Digitalization and participates in the project "Secure Digital Identity," which aims, among other things, to protect against fraud and cyberattacks and to defend data privacy.

(...).

2. Measures implemented by ORANGE to prevent the commission of fraud resulting from the impersonation of ORANGE agents and/or employees.

- Implementation of a two-factor identification system, which is in the testing phase with certain users.

- Project (...).

- Traffic control tools, which are used by ORANGE's Risk Analysis Group, and which can generate alerts in case of possible detections of irregular contracts, and which works as follows in the case of duplicate SIM cards:

(...)

3. Measures adopted concerning the present case, not covered in the previous sections.

- The risk associated with this type of case has been modified, having a greater impact on the company's protocols and actions.

- The (...) that occurs in cases like the one that prompted the opening of this sanctioning procedure has been provisionally suspended, in order to determine the appropriate measures to mitigate the identified risks.

In any case, ORANGE wants to state that it carries out constant monitoring and review of the existing risks regarding duplicate SIM cards, that the protocols are updated, and that measures are adopted in accordance with the identified risks, without this allowing for the imposition of a guarantee or requirement of infallibility.

ORANGE states that this Agency has not reviewed this breakdown, and understands that it is necessary to comprehend the threat and to be able to prevent and mitigate its commission, and adds that this would have demonstrated its

C/ Jorge Juan, 6

www.aepd.es

28001 – Madrid

sedeagpd.gob.es

52/63

the will to protect the rights of individuals, in which the existence of a zero risk is updated and reviewed.

This Agency understands that ORANGE continues to assert that it complies with the provisions of Article 25 of the GDPR. In this case, it reiterates the measures that it had implemented and states that this Agency has not taken them into account.

Some of the measures highlighted by ORANGE are not applicable to cases where the request for SIM cards is made in person. The processing of data not only requires the establishment of cybersecurity measures but also necessitates other measures to mitigate the risks that arise (...).

ORANGE claims that the possibility of duplicating SIM cards from the customer area and from kiosks has been eliminated; it has been implemented (...); the risk associated with this type of case has been modified, having a greater impact on the company's protocols and actions, and precautionary measures have been suspended (...) that occur in cases like the one that prompted the initiation of this sanctioning procedure, in order to determine the appropriate measures to mitigate the identified risks.

Well, all these measures were not implemented by ORANGE beforehand, but rather have been applied after the events, so they were not taken into account from the design of the processing; therefore, they cannot be considered in the present case either.

In the fifth section of the response to the allegations regarding the initiation agreement, it states,

regarding the documents provided by ORANGE, the following:

It is documentation that refers to the possibility of the existence of risks, but does not specifically identify them, and does not foresee specific actions regarding the possibility that situations like the one that has occurred in this sanctioning file may arise, as it does not mention specifically the possibility that (...).

There is no document that foresees what the risks are (...). It has already been mentioned in the response to these allegations that, from this Agency, it cannot be considered that the possibility of employees being able to duplicate a SIM card can be classified as low, but this would not imply that all employees are potential criminals, only that this possibility must be assessed and measures must be in place regarding it, especially considering the impact on the rights and freedoms of individuals.

ORANGE states that (...).

In its appeal, ORANGE points out that, "among the technical measures, it is necessary to mention the DNI verification system, a system that is an additional measure, not predominant over other measures, which involves a significant economic investment in security and whose manipulation by an agent with bad faith severely penalizes ORANGE before this Agency." In this regard, ORANGE again implies that the risk that its actions may pose to the rights and freedoms of individuals does not take precedence in its security measures, but rather to those of the organization. It has already been mentioned several times in this file that the system it has implemented to verify the DNI in the processes of duplicating SIM cards does not meet the requirements set forth in Article 25 of the GDPR, and the company again refers, at this point, to other files in which, according to its statement, the implemented measures were indeed relevant. In this regard, it should be noted that in those files there was no reference to the DNI verification system in the issuance of duplicate SIM cards in person. Therefore, this allegation cannot be taken into account.

For all these reasons, it is appropriate to reject the allegation presented by ORANGE.

9.- ON THE LACK OF PROPORTIONALITY OF THE PROPOSED SANCTION.

ORANGE, in its appeal, points out that it would have demonstrated that it acted with due diligence in the processes of duplicating SIM cards. This Agency wishes to point out that it has been demonstrated that this was not the case throughout the resolution that is now being appealed.

In any case, it also wishes to point out that the imposed sanction is disproportionate and expresses its disagreement with the assessment of the aggravating factors, making an argument that has already been analyzed in the appealed resolution as follows:

"ORANGE makes this assertion stating that it has demonstrated that it acted with due diligence in the implementation of measures in the processes of duplicating SIM cards, and that in this case the agents acted individually and maliciously breaking the standards and protocols of the company.

In any case, it understands that the sanction included in the initiation agreement is disproportionate considering the circumstances and content of the alleged infringement, which ORANGE denies.

Regarding the violation of the principle of proportionality, the GDPR expressly provides for the possibility of graduation, through the provision of fines that can be modulated, taking into account a series of effective, proportional, and deterrent circumstances of each individual case (Article 83.1 and 2 GDPR), general conditions for the imposition of administrative fines that have indeed been analyzed by this Agency, to which the graduation criteria set forth in the LOPDGDD must be added.

It should be noted that the agreed administrative fine will be effective because

C/ Jorge Juan, 6

www.aepd.es

28001 – Madrid

sedeagpd.gob.es

54/63

will lead the company to implement the technical and organizational measures that guarantee the rights and freedoms of the data subjects, taking into account the criticality of the processing.

It is also proportional to the identified violation, particularly regarding its severity, the circle of affected individuals, and the risks incurred, as well as the financial situation of the company.

And, finally, it is deterrent. A deterrent fine is one that has a genuine deterrent effect. In this regard, the Judgment of the CJEU, dated June 13, 2013, Versalis Spa/Commission, C-511/11,

ECLI:EU:C:2013:386, states:

“94. Regarding, first of all, the reference to the Showa Denko/Commission judgment, previously cited, it should be noted that Versalis misinterprets it. Indeed, the Court of Justice, by stating in paragraph 23 of that judgment that the deterrent factor is assessed taking into account a multitude of elements and not just the particular situation of the company in question, was referring to points 53 to 55 of the conclusions presented in that case by Advocate General Geelhoed, who essentially pointed out that the deterrent multiplier coefficient may aim not only at a ‘general deterrence,’ defined as an action to disincentivize all companies, in general, from committing the infringement in question, but also at a ‘specific deterrence,’ consisting of deterring the specific defendant from infringing the rules again in the future. Therefore, the Court of Justice merely confirmed, in that judgment, that the Commission was not obliged to limit its assessment to factors solely related to the particular situation of the company in question.”

“102. According to established case law, the objective of the deterrent multiplier factor and the consideration, in this context, of the size and overall resources of the company in question lies in the desired impact on the aforementioned company, as the sanction should not be insignificant, especially in relation to the financial capacity of the company (in this sense, see, in particular, the judgment of June 17, 2010, Lafarge/Commission, C-413/08 P, Rec. p. I-5361, paragraph 104, and the order of February 7, 2012, Total and Elf Aquitaine/Commission, C-421/11 P, paragraph 82).”

The Judgment dated May 11, 2006, issued in the cassation appeal 7133/2003 establishes that: “It should also be taken into account that one of the guiding criteria for the application of this principle of administrative sanctioning regime (a criterion included under the heading of ‘principle of proportionality’ in paragraph 2 of Article 131 of the aforementioned Law 30/1992) is that the imposition of monetary sanctions should not result in the commission of the classified infringements being more beneficial for the offender than compliance with the infringed rules.”

The case law resulting from the Judgment of the Third Chamber of the Supreme Court, issued on May 27, 2003 (rec. C/ Jorge Juan, 6

www.aepd.es

28001 – Madrid

sedeagpd.gob.es

55/63

3725/1999) which states: Proportionality, specifically belonging to the realm of sanctions, constitutes one of the principles governing Administrative Sanctioning Law, and represents a tool for controlling the exercise of sanctioning power by the Administration within, even, the margins that the applicable norm initially indicates for such exercise. It certainly involves a concept that is difficult to determine a priori, but it tends to adjust the sanction by establishing its specific gradation within the indicated possible margins, according to the severity of the act constituting the infringement, both in its aspect of unlawfulness and culpability, weighing in its entirety the objective and subjective circumstances that integrate the factual presumption subject to sanction - and, in particular, as results from Article 131.3 of the LRJ and PAC, the intent or repetition, the nature of the damages caused, and recidivism. (SSTS July 19, 1996, February 2, 1998, and December 20, 1999, among many others).

In this case, ORANGE highlighted that it had demonstrated having acted diligently in the processes of duplicate SIM cards, and that, in this case, the agents acted individually and with intent, breaking the company's protocols.

Thus, from this AEPD, it is intended to indicate that, in this case, the actions of the agents are not being examined, but rather the condition, characteristics, and adequacy of the measures adopted by ORANGE, and the actions of the data controller in this regard.

ORANGE wishes to express its disagreement with the interpretation made by this Agency regarding the aggravating factors:

a) the nature, severity, and duration of the infringement (Article 83.2.a) RGPD. ORANGE states that this aggravating factor is based on the possible commission of fraudulent banking operations, and considers that it is not legally acceptable to use as an argument the use of bank accounts, the monetary damages of the victims of the frauds, or the manner in which these operations are carried out by financial entities to justify the imposed sanction, to the extent that "the banking entities are the

only ones responsible for the security of their operations, as stated by the European Banking Authority, in 'Opinion on the implementation of the RTS on SCS and CSC' points 37 and 38, where it is determined that the security credentials used to perform the secure authentication of users of payment services are the responsibility of the account management entity.

In this regard, the Agency considers that the nature of the infringement is very serious since it entails a loss of disposition and control over personal data. It has allowed criminals to steal identity by hijacking the phone number after obtaining a duplicate of the SIM card. After the entry into force of the PSD2 Directive, as indicated, the mobile phone has taken on a very important role in making online payments as it is necessary for the confirmation of transactions, and

C/ Jorge Juan, 6
www.aepd.es
28001 – Madrid
sedeagpd.gob.es
56/63

This device - and by extension the SIM card - becomes a clear target for cybercriminals.

It is worth noting that the PSD2 Directive applies to payment services provided within the Union (Article 2), and not to ORANGE, but it is also true that the issuance of a duplicate SIM card in favor of a third party who is not the line holder provides impersonators with control over the telephone line, and therefore, over the SMS directed to the phone linked to the initial SIM card, thus allowing access to the authentication code of the transaction.

It is true that, beforehand, access data to online banking must be known, but it is also necessary to obtain the duplicate of the SIM card belonging to the person to be defrauded in order to obtain the confirmation SMS that the customer will receive on their mobile terminal as two-factor authentication, and it is this action (the obtaining of the duplicate) that has been taken into account in the present sanctioning procedure.

Regarding the aggravating factor related to the infringement of Article 25 of the GDPR, ORANGE understands that not all customers should be considered, as not all are natural persons, nor do all request a duplicate of the SIM card. Therefore, it understands that, in this case, there would only be one implicated party, which would be the person who filed the complaint.

However, this Agency has already determined that the responsibility attributed to ORANGE is for not having the appropriate technical and organizational measures in place to ensure data protection for customers from the design stage.

The Agency considers that the level of possible harm is high, as access to duplicates of these SIM cards allows for fraudulent banking operations to be carried out in a short period of time. Through the duplication of SIM cards, the alleged impersonators can gain control of the subscriber's line and thereby receive SMS directed to the legitimate subscriber to confirm online transactions while impersonating their identity. These SMS are sent by banking entities as part of the two-step verification of operations such as money transfers or online payments, and access to these SMS is often the reason for the fraudulent duplication of SIM cards.

It is true that ORANGE is not responsible for the customer identification policies established by banking entities nor can it be held liable for banking fraud. However, it is also true that if ORANGE ensured the identification and delivery procedure, the verification system of the banking entities could not even be activated. The fraudster, after obtaining the activation of the new SIM, takes control of the telephone line, thus being able to carry out fraudulent banking operations by accessing the SMS that banking entities send to their customers. This sequence of events generates a series of serious damages and harms that should have been taken into account in an evaluation of

C/ Jorge Juan, 6
www.aepd.es
28001 – Madrid
sedeagpd.gob.es
57/63

impact regarding data protection (recitals 89, 90, 91 and Article 35 of the GDPR) or in the

corresponding risk analysis. Ultimately, from the moment a duplicate is delivered to a person other than the line holder or an authorized person, the customer loses control of the line and the risks, damages, and losses multiply. Furthermore, the events occur with overwhelming immediacy. In summary, the application of Article 83.2.a) of the GDPR refers to the severity of the Established Facts, which is evidenced, among other issues, by the social alarm generated by the execution of these fraudulent practices and by the extremely high probability of risk materialization, without the number of claims filed being decisive. This is because what has been analyzed in the present sanctioning procedure are the technical and organizational measures implemented by the data controller following the complaint filed with the AEPD.

Regarding ORANGE's statement that not all customers considered in the initiation agreement to determine the number of affected individuals are natural persons, it should be noted that this Agency has taken the data from its website, and can provide the number of customers who are natural persons, although, as already mentioned, in the application of Article 83.2.a) the number of customers has been taken into account, but also the social alarm generated by the execution of these fraudulent practices and by the extremely high probability of risk materialization, without the number of claims filed being decisive.

b) any prior infringement committed by the data controller or processor (Article 83.2.e GDPR)

ORANGE points out that prior infringements that have been committed and sanctioned should not be taken into account, as they are not related to the present case. However, subsection e) of Article 83.2 of the GDPR expressly states "any prior infringement committed by the controller," so all cases reflected in the initiation agreement would fall within this, considering that it is never indicated that such infringements must be the same as the case in question.

c) the link between the business activity of the respondent and the processing of personal data of customers or third parties (Article 83.2.k GDPR in relation to Article 76.2.b) LOPDGDD.)

ORANGE states that this factor is ambiguous in its assessment for inclusion as an aggravating factor, as such a link does not imply a direct relationship with the alleged infringement, and furthermore, it requires that this aggravating factor be related to the specific factual situation, and therefore the processing of data does not arise from an intention of the entity, but rather occurs in the commission of a crime.

However, this Agency takes into account that the development of the business activity carried out by ORANGE requires data processing.

C/ Jorge Juan, 6
www.aepd.es
28001 – Madrid
sedeagpd.gob.es
58/63

continuously and on a large scale the personal data of customers, including the issuance of duplicate SIM cards, ORANGE is positioned as one of the major telecommunications operators in our country. It is evident that ORANGE's activity necessarily involves carrying out a high number of operations for processing personal data of the natural persons who are customers of this entity, which impacts the diligence that must be exercised in complying with the obligations arising from this data processing. Furthermore, it cannot be overlooked that this specific factual situation arises from a lack of adequate technical and organizational measures on the part of ORANGE.

Finally, it should be added that it is the legislator who foresaw the possibility of using this aggravating factor and that the Agency is limited to applying it.

d) Intent or negligence in the infringement.

ORANGE states that this Agency does not relate this aggravating factor, nor does it indicate its application to the present factual situation.

Thus, it understands that, as stated by the CJEU when it indicated that the imposition of coercive sanctions by the administrative authority is only admissible in cases where culpable conduct by the responsible party or data processor is evident, the imposition of this aggravating factor should be reserved for cases where intent or negligence is evident or serious.

Therefore, in this case, where the situation arises from a criminal act not attributable to ORANGE, it

believes that this aggravating factor should not be attributed without any reasoning in this regard. Regarding the fact that the situation that has led to the opening of this sanctioning file is caused by a criminal act not attributable to ORANGE, it reiterates what has already been stated in this resolution proposal concerning the fact that what is attributed to ORANGE is the failure to implement the necessary measures to prevent the duplication of the SIM card in the terms in which it has occurred. In this sense, if ORANGE had been diligent in implementing the appropriate measures for the issuance of duplicate SIM cards, a situation like the one reported by the complainant would not have occurred. Moreover, it is considered that ORANGE's conduct corresponds to the infringing type and the title of fault, being deemed to have acted with serious negligence in the infringement of Article 25. As a large-scale holder of personal data, therefore, accustomed or specifically dedicated to the management of customers' personal data, it must be especially diligent and careful in its processing. In other words, from the perspective of culpability,

C/ Jorge Juan, 6
www.aepd.es
28001 – Madrid
sedeagpd.gob.es
59/63

We are facing a correctable error, as the application of appropriate technical and organizational measures could have prevented these identity thefts.

Although the Agency considers that there was no intent on the part of ORANGE, it concludes that it was negligent in failing to ensure a procedure that guaranteed the protection of customers' personal data. Thus, a socially harmful result occurs that imposes disapproval of the ineffective measures implemented, regardless of the level of commitment demonstrated, which is unquestionable.

Denying the occurrence of negligent conduct by ORANGE would be equivalent to acknowledging that its behavior—by action or omission—has been diligent. Obviously, we do not share this perspective of the facts, as the lack of due diligence has been established. A large company that processes personal data of its customers on a large scale, systematically and continuously, must exercise extreme care in fulfilling its obligations regarding data protection, as established by jurisprudence.

The SAN of October 17, 2007 (rec. 63/2006) is very illustrative; starting from the premise that these are entities whose activity involves continuous processing of customer data, it indicates that "...the Supreme Court has understood that there is imprudence whenever a legal duty of care is neglected, that is, when the offender does not behave with the required diligence. And in assessing the degree of diligence, the professionalism or lack thereof of the subject must be especially weighed, and there is no doubt that, in the case now examined, when the activity of the appellant involves constant and abundant handling of personal data, it must be insisted upon the rigor and exquisite care to comply with the legal provisions in this regard."

In this sense, it is of vital importance to establish and implement the necessary procedures and measures, depending on the characteristics and entity of the operator, that allow demonstrating that due diligence was exercised in attempting to prevent identity theft. Furthermore, it must be possible to demonstrate that the necessary precautions were taken during the course of business activities, as required by regulations, to avoid foreseeable harm. This involves having an objective level of care considering the specific circumstances of the case that makes it evident that one was aware of the possibility of suffering identity theft, and that, consequently, appropriate measures were applied to minimize the realization of such risk as much as possible.

Likewise, regarding the application of this circumstance as an aggravating factor, the Audiencia Nacional has ruled in its SAN of March 1, 2024 (Case Number: 0001757/2021) that the application of the circumstance contemplated in Article 83.2.b) of the GDPR is appropriate in cases of lack of diligence by entities that carry out large-scale data processing, specifying that "(...) And in this sense, it should be noted that a company like the plaintiff that carries out data processing..."

C/ Jorge Juan, 6
www.aepd.es
28001 – Madrid
sedeagpd.gob.es

Personal data of its clients on a large scale, systematically and continuously must exercise extreme care in complying with its obligations regarding data protection. The plaintiff emphasizes the absence of intent when the provision also speaks of negligence, and it is this lack of diligence that the contested resolution highlights in relation to both infringements (...)

For this reason, the application of the circumstance contemplated in Article 83.2.b) of the GDPR is considered justified.

On the other hand, ORANGE states that the following mitigating factors should have been taken into account:

- The respondent blocked the line as soon as it became aware of the facts. (art. 83.2.c).

This mitigating factor cannot be considered when, as a consequence of the alleged infringement, the claimant has suffered losses amounting to 9,000 euros.

- Special categories of data have not been processed (art. 83.2.g).

This allegation cannot be taken into account insofar as processing personal data included within the category of special data can be considered an aggravating factor for the calculation of the sanction, but processing personal data that is not included within this category can never be considered a mitigating factor when imposing a sanction. Furthermore, it is taken into account that the SIM card is a personal data that has a particularly sensitive nature, as it enables identity theft.

- The degree of cooperation of ORANGE with the AEPD. In this way, ORANGE wants to express that it has been proven that it has responded in a timely manner to all information requests made, in order to remedy an alleged infringement and mitigate its possible adverse effects (art. 83.2.f).

This allegation cannot be taken into account as responding to information requests sent from this Agency is an obligation of the data controller, as stated in the LOPDGDD.

- Adherence to codes of conduct under Article 40 or certification mechanisms approved under Article 42 (art. 83.2.j).

ORANGE submits as document No. 15 a certificate issued by AENOR, which certifies that ORANGE has had an approved compliance system since September 4, 2023, which meets the requirements of Article 31 bis of the Penal Code, as well as other compliance standards in the area of crime prevention, such as Circular 1/2016, of January 22, from the Attorney General's Office, aimed at mitigating any risk of committing crimes in the context of ORANGE's actions.

This certification cannot be taken into account when determining corrective powers, as it is not a matter of proving that compliance measures have been adopted in criminal matters, but rather of proving that standards in data protection are met.

- The nonexistent benefit obtained by ORANGE in the processing of the data that occupies this sanctioning procedure, adding that, in any case, it would be harmed, as already noted, being a harmed party in the criminal procedure in which the commission of the crime in question is reported (83.2.k).

This allegation presented by ORANGE cannot be taken into account, as the fact that no benefits have been obtained cannot be considered a mitigating factor, according to the ruling of the National Court, dated 05/05/2021, rec. 1437/2020, which states: "On the other hand, it must be appreciated as a mitigating factor the non-commission of a previous infringement. Well, Article 83.2 of the GDPR establishes that the following circumstance must be taken into account for the imposition of the administrative fine, among others, the circumstance "e) any previous infringement committed by the data controller or the processor." It is an aggravating circumstance; the fact that the prerequisite for its application does not occur means that it cannot be taken into consideration, but it does not imply or allow, as the plaintiff intends, its application as a mitigating factor"; applied to the case under review, the lack of the prerequisite for its application regarding art. 76.2.c) of the LOPDGDD, that is, obtaining benefits as a consequence of the infringement, does not allow its application as a mitigating factor."

Thus, in accordance with the provisions of Article 83.1 of the GDPR, admitting the absence of benefits as a mitigating factor is not only contrary to the factual prerequisites contemplated in Article 76.2.c), but also contrary to what is established in Article 83.2.k) of the GDPR and to the principles mentioned. Therefore, valuing the absence of benefits as a mitigating factor would nullify the deterrent effect of the fine, as it diminishes the effect of the circumstances that effectively impact its quantification, providing the data controller with a benefit to which it has not earned entitlement. It would be an artificial

reduction of the sanction that could lead to the understanding that violating the norm without obtaining benefits, financial or otherwise, will not produce a negative effect proportional to the severity of the infringing act.

In any case, the administrative fines established in the GDPR, according to what is established in its Article 83.2, are imposed based on the circumstances of each individual case and it is not considered that the absence of benefits is an adequate and determining factor for assessing the severity of the infringing conduct. Only in the event that this absence of benefits is...

C/ Jorge Juan, 6

www.aepd.es

28001 – Madrid

sedeagpd.gob.es

62/63

relevant to determine the degree of unlawfulness and culpability present in the specific infringing action may be considered as a mitigating factor, in application of Article 83.2.k) of the GDPR, which refers to "any other aggravating or mitigating factor applicable to the circumstances of the case."

For all these reasons, it is appropriate to dismiss the present allegation.

III

Conclusion

Consequently, in the present appeal for reconsideration, the appellant has not provided new facts or legal arguments that would allow for a reconsideration of the validity of the contested resolution.

IV

Late Resolution

Due to reasons related to the functioning of the administrative body, therefore not attributable to the appellant, as of the date of this document, the mandatory pronouncement of this Agency regarding the present appeal has not been issued.

According to the provisions established in Article 24 of the LPACAP, the meaning of administrative silence in the procedures for challenging acts and provisions is dismissive.

Nevertheless, and despite the time elapsed, the Administration is obliged to issue an express resolution and to notify it in all procedures, regardless of their initiation form, as provided in Article 21.1 of the aforementioned LPACAP.

Therefore, it is appropriate to issue the resolution that concludes the procedure of the appeal for reconsideration filed.

In view of the cited provisions and others of general application, the Spanish Agency for Data Protection RESOLVES:

FIRST: TO DISMISS the appeal for reconsideration filed by ORANGE ESPAGNE, S.A.U. against the resolution of this Spanish Agency for Data Protection issued on October 22, 2024, in file EXP202213023.

SECOND: TO NOTIFY this resolution to ORANGE ESPAGNE, S.A.U.

THIRD: To warn the sanctioned party that the imposed sanction must be made effective once this resolution is notified, in accordance with the provisions of Article 98.1.b) of Law 39/2015, of October 1, on the Common Administrative Procedure of Public Administrations, within the voluntary payment period specified in Article 68 of the General Collection Regulation, approved by Royal Decree 939/2005, of July 29, in relation to Article 62 of Law 58/2003, of December 17, by depositing it in the restricted account No. ES00 0000 0000 0000 0000 0000, opened in the name of the Spanish Agency for Data Protection at CAIXABANK, S.A., or otherwise, it will proceed to its collection in the executive period.

If the date of notification falls between the 1st and the 15th of each month, inclusive, the deadline for voluntary payment will be until the 20th of the following month or the next business day, and if it falls between the 16th and the last day of each month, inclusive, the payment deadline will be until the 5th of the second following month or the next business day.

In accordance with the provisions of Article 50 of the LOPDGGDD, this Resolution will be made public once it has been notified to the interested parties.

Against this resolution, which concludes the administrative route in accordance with Article 48.6 of the LOPDGDD, and in accordance with the provisions of Article 123 of Law 39/2015, of October 1, on the Common Administrative Procedure of Public Administrations (LPACAP), the interested parties may file a contentious-administrative appeal before the Contentious-Administrative Chamber of the National Court, in accordance with the provisions of Article 25 and Section 5 of the fourth additional provision of Law 29/1998, of July 13, regulating Contentious-Administrative Jurisdiction, within two months from the day following the notification of this act, as provided in Article 46.1 of the aforementioned Law. Finally, it is noted that in accordance with the provisions of Article 90.3 a) LPACAP, the firm resolution in the administrative route may be provisionally suspended if the interested party expresses their intention to file a contentious-administrative appeal. If this is the case, the interested party must formally communicate this fact by means of a written document addressed to the Spanish Agency for Data Protection, submitting it through the Agency's Electronic Registry [<https://sedeagpd.gob.es/sede-electronica-web/>], or through any of the other registries provided for in Article 16.4 of the aforementioned LPACAP. They must also provide the Agency with documentation that proves the effective filing of the contentious-administrative appeal. If the Agency does not have knowledge of the filing of the contentious-administrative appeal within two months from the day following the notification of this resolution, it will consider the provisional suspension to be concluded.

1245-21112023

Olga Pérez Sanjuán

The Deputy Director General of Data Inspection, in accordance with Article 48.2 LOPDGDD, due to the vacancy of the Presidency and Deputy Presidency

C/ Jorge Juan, 6

www.aepd.es

28001 – Madrid

sedeagpd.gob.es